



*Asociación Profesional de Cuerpos Superiores
de Sistemas y Tecnologías de la Información
de las Administraciones Públicas.*

Temas Específicos para la preparación de la Oposición al Cuerpo
Superior de Sistemas y Tecnologías de la Información de la
Administración del Estado.

TEMAS ESPECÍFICOS II: Tecnología básica

Tema 81. Identificación y firma electrónica (2) Prestación de servicios públicos y privados. Infraestructura de clave pública (PKI). Mecanismos de identificación y firma: «Smart Cards», DNI electrónico, mecanismos biométricos

AUTOR: Rafael Pérez Galindo

Actualización 2017

ÍNDICE

1.	IDENTIFICACIÓN ELECTRÓNICA.....	5
1.1	PRESTACIÓN DE SERVICIOS DE IDENTIDAD ELECTRÓNICA.....	5
1.1.1	PRESTADORES DE IDENTIDADES PÚBLICOS	6
1.1.2	PRESTADORES DE IDENTIDADES PRIVADOS.....	6
1.2	RECONOCIMIENTO MUTUO DE IDENTIDADES ELECTRÓNICAS	7
2.	PRESTACIÓN DE SERVICIOS ELECTRÓNICOS DE CONFIANZA	7
2.1	RÉGIMEN DE SUPERVISIÓN Y CONTROL	8
2.2	LISTA DE SERVICIOS DE CONFIANZA (TSL)	9
2.3	INICIO DE LA PRESTACIÓN DE UN SERVICIO CUALIFICADO	10
2.4	REQUISITOS DE SEGURIDAD APLICABLES A LOS TSP Y QTSP	11
2.5	RÉGIMEN DE RESPONSABILIDAD DE LOS PRESTADORES.....	11
2.6	TRANSICIÓN ENTRE LA DIRECTIVA/LEY Y EL REGLAMENTO	11
2.7	ASPECTOS ADICIONALES EN LA FUTURA LEY DE SERVICIOS DE CONFIANZA	11
3.	SERVICIOS EIDAS PARA LAS ADMINISTRACIONES PÚBLICAS	12
3.1	NODO EIDAS DE ESPAÑA.....	12
3.2	PLATAFORMA DE SERVICIOS @FIRMA.	13
4.	INFRAESTRUCTURA DE CLAVE PÚBLICA (PKI): DEFINICIÓN Y TIPOS	14
4.1	DEFINICIÓN	14
4.2	TIPOS DE PKI	15
4.2.1	PKI BASADAS EN AUTORIDADES DE CERTIFICACIÓN (CA) X.509	15
4.2.2	PKI BASADAS EN REDES DE CONFIANZA.....	15
4.2.3	COMPARATIVA ENTRE PKI X.509 Y PKI PGP	16
4.2.4	OTRAS SOLUCIONES.....	16
5.	COMPONENTES PRINCIPALES DE UNA PKI X.509.....	17
5.1	AUTORIDAD DE CERTIFICACIÓN (CERTIFICATION AUTHORITY, CA)	17
5.2	AUTORIDAD DE REGISTRO (REGISTRATION AUTHORITY, RA)	20
5.3	AUTORIDAD DE VALIDACIÓN (VALIDATION AUTHORITY, VA).....	20
5.4	PROVEEDORES DE CA.....	21
5.5	IMPACTO DE LA COMPUTACIÓN CUÁNTICA.....	21
5.6	PKI EN LA ARQUITECTURA DE INTERNET	21

6.	MECANISMOS DE IDENTIFICACIÓN Y FIRMA	22
6.1	ALMACENAMIENTO SEGURO DE CLAVES PRIVADAS.....	22
6.1.1	TARJETAS INTELIGENTES	22
6.1.2	PADS	28
6.1.3	TOKEN CRIPTOGRÁFICO	29
6.1.4	HARDWARE SECURITY MODULE (HSM). FIRMA EN LA NUBE	29
6.1.5	CARTERAS DE BITCOINS	30
6.2	MECANISMOS BIOMÉTRICOS	31
6.2.1	RENDIMIENTO	31
6.2.2	ESTANDARIZACIÓN	31
6.2.3	TECNOLOGÍAS BIOMÉTRICAS	33
6.2.4	RETOS	33
6.3	AUTENTICACIÓN MULTIFACTOR. FIDO.	34
7.	DNI ELECTRÓNICO	35
7.1	CONCEPTO	35
7.2	MARCO JURÍDICO	36
7.3	USUARIOS	36
7.4	DNI EN TARJETA	36
7.4.1	TARJETAS FÍSICAS	38
7.4.2	CHIPS.....	39
7.4.3	CERTIFICACIÓN DE LA TARJETA COMO DISPOSITIVO CUALIFICADO DE CREACIÓN DE FIRMA.....	40
7.5	CL@VE (DNI EN LA NUBE).....	41
7.6	PERIODO DE VALIDEZ.....	41
7.7	PARTICULARIDADES DE LA PKI DEL DNIE	42
7.7.1	ARQUITECTURA.....	42
7.7.2	AUTORIDADES DE REGISTRO.....	42
7.7.3	AUTORIDADES DE VALIDACIÓN	42
7.8	REQUISITOS PARA SU USO	43
7.8.1	MEDIANTE CONTACTOS.....	43
7.8.2	MEDIANTE NFC (SIN CONTACTOS).....	44
7.9	APLICACIONES	44
7.10	SEGURIDAD	44
7.10.1	AUTENTICACIÓN	44
7.10.2	SECURIZACIÓN DE MENSAJES.....	46

7.10.3 DESBLOQUEO Y CAMBIO DE PIN.....	46
7.10.4 FUNCIONALIDAD CRIPTOGRÁFICA	46
7.10.5 INTERCAMBIO DE CLAVES.....	47
7.10.6 CIFRADO	47
7.10.7 APLICACIONES DE FIRMA	47
7.10.8 REQUISITOS DE SEGURIDAD DEL ENTORNO	47

1. Identificación electrónica

En el contexto de la regulación comunitaria sobre identificación electrónica y servicios de confianza, representada por el **Reglamento (UE) 910/2014** (conocido como **Reglamento eIDAS**) y sus disposiciones de desarrollo, estudiado en el tema anterior, así como la Ley 59/2003, de firma electrónica, se desarrollan los mercados de prestación de identidades electrónicas y servicios de confianza.

Téngase en cuenta que el Reglamento (UE) 910/2014 derogó la Directiva 1999/93/CE en fecha de 1 de julio de 2016, por lo que desde ese momento la Ley 59/2003, de firma electrónica, se encuentra desplazada jurídicamente por la legislación comunitaria. Para evitar posibles situaciones de inseguridad jurídica, la futura Ley de Servicios de Confianza ordenará la situación de los prestadores de servicios así como de los efectos jurídicos de los servicios cualificados que prestan, adaptando el ordenamiento jurídico español al nuevo marco legislativo comunitario, derogando la Ley de firma electrónica, y desarrollando el Reglamento (UE) 910/2014 en los aspectos que éste prevé expresamente que sean abordados por las legislaciones nacionales.

1.1 Prestación de servicios de identidad electrónica

De acuerdo con el Reglamento eIDAS, esta actividad no está regulada en sí misma, puesto que no se establecen requisitos a los prestadores de identidades, ni se les somete a un régimen de supervisión y sancionador específico. Tampoco se detiene el Reglamento a legislar ni estandarizar las tecnologías empleadas por los proveedores de identidades electrónicas.

Pueden ser prestados **tanto por entidades públicas como privadas**, en principio en igualdad de condiciones y libre competencia. Otra cosa será su grado de aceptación en el acceso a los servicios públicos o privados en función de su nivel de seguridad o las exigencias legales.

Respecto al acceso a los servicios ofrecidos por el sector público, la Ley 39/2015 indica en su artículo 9 que las Administraciones públicas están obligadas a verificar la identidad de los interesados en el procedimiento administrativo, mediante la comprobación de su nombre y apellidos o denominación o razón social, que consten en el DNI o documento identificativo equivalente, así como que los interesados podrán identificarse electrónicamente ante las Administraciones públicas a través de cualquier sistema que cuente con un registro previo como usuario que permita garantizar su identidad, pero no establece restricciones en relación con la naturaleza pública o privada del proveedor de identidades electrónico que el interesado decida utilizar.

Es importante también destacar que de nuevo la Ley 39/2015 establece en su artículo 10.4 que cuando los interesados utilicen un sistema de firma, su identidad se entenderá ya acreditada mediante el propio acto de la firma. Se sobreentiende que este precepto se refiere a los casos en los que la firma acredite unívocamente la identidad del firmante, lo cual podría no ser siempre así. En cualquier caso, esta disposición implica que con carácter general los certificados electrónicos cualificados expedidos por prestadores de servicios de confianza establecidos en España podrán utilizarse como medio de identificación electrónica, evitando la necesidad de poseer un medio expreso para este fin.

No obstante, también ha de significarse que de acuerdo con la citada Ley 39/2015 sólo se puede exigir firma electrónica a los interesados que deseen:

- a) Formular solicitudes.
- b) Presentar declaraciones responsables o comunicaciones.
- c) Interponer recursos.
- d) Desistir de acciones.
- e) Renunciar a derechos,

debiendo ser suficiente la identificación electrónica para el resto de acciones.

1.1.1 Prestadores de identidades públicos

Se presenta a continuación una enumeración no exhaustiva de las iniciativas más importantes:

- **Cl@ve Identificación:** se ha estudiado en el tema anterior.

Simplemente se destaca que el Acuerdo de Consejo de Ministros que aprobó la plataforma Cl@ve prevé que *“Este sistema de identificación y firma electrónica podrá evolucionar en el futuro para admitir también la participación del sector privado en su provisión, o su combinación con otras soluciones tecnológicas ofrecidas por empresas especializadas”*.

- **DNle**

El DNI electrónico contiene un certificado de autenticación y otro de firma electrónica. Téngase en cuenta que los certificados de autenticación no se encuentran regulados por el Reglamento (UE) 910/2014, y el artículo 10.4 de la Ley 39/2015 tiene como consecuencia que realmente pueda no tener sentido su expedición independiente del certificado de firma.

- **Prestadores de servicios de confianza públicos**

De acuerdo con el artículo mencionado, los certificados de firma electrónica expedidos por cualquier prestador de servicios de confianza público podrían ser utilizados para la identificación electrónica del interesado.

1.1.2 Prestadores de identidades privados

Se presenta a continuación una enumeración no exhaustiva de las iniciativas más importantes:

- **Bancos**

Téngase en cuenta que en otros países europeos, típicamente los escandinavos, las entidades bancarias actúan como proveedores de identidades, por ejemplo BankID en Noruega. No hay en este sentido restricciones en los esquemas de identificación electrónica que pueden ser comunicados a la Comisión con objeto de su reconocimiento transfronterizo de cara a 2018, siempre y cuando las autenticaciones sean gratuitas para el acceso a servicios públicos online y se cumplan el resto de requisitos.

- **GSMA**

Ciertas operadoras de telecomunicaciones han constituido GSMA (en España, Telefónica, Orange y Vodafone) como proveedor privado de identidades electrónicas, con las que sus abonados pueden acceder a servicios online tanto públicos como privados a través de doble factor de autenticación a través del terminal móvil.

Ciertos sectores de actividad económica pueden estar receptivos a este tipo de soluciones (nueva banca electrónica, comercio electrónico, educación, salud, energía...), e incluso el acceso a procedimientos administrativos online.

- **Redes sociales**

Otra cuestión es la posibilidad de permitir que sistemas en los que no se garantiza completamente la identidad del interesado pudiesen tener cabida para determinados procedimientos, en virtud del principio de proporcionalidad, como la identificación ligera en redes sociales, que posee gran usabilidad, pero que adolece en general de falta de garantías mínimas exigibles para que un interesado pudiese utilizarlas para relacionarse con la Administración en la mayoría de los casos, a no ser que se fortaleciesen sus procedimientos de registro.

No obstante, como es conocido se utiliza habitualmente el “social login” proporcionado por plataformas como Facebook o Google en otros accesos menos críticos a servicios proporcionados por terceras partes.

- **Alastria**

Es un consorcio multisectorial español fundado para aunar esfuerzos en la creación de una plataforma transversal, de código abierto y neutra basada en *blockchain* y tecnologías de registros compartidos (DLT). El primer proyecto de Alastria va a enfocarse en el desarrollo de un sistema de

identificación digital que pueda ser compartido de manera segura para el soporte a la contratación (smart-contracts) en los procesos empresariales, como el registro de nuevos clientes en entidades financieras o empresas de servicios como las eléctricas o las operadoras de telecomunicaciones, así como facilitar las gestiones de los ciudadanos con las Administraciones públicas.

1.2 Reconocimiento mutuo de identidades electrónicas

Como se ha comentado, el Reglamento eIDAS señala que la provisión de identidades electrónicas puede ser efectuada por entidades públicas o privadas, y ello es independiente de la posibilidad de notificación de un esquema determinado de identificación a la Comisión Europea por parte de un Estado miembro para que goce del reconocimiento transfronterizo gratuito en el acceso a servicios públicos online de toda la UE.

También define el Reglamento los niveles de seguridad bajo, sustancial y alto (desarrollados en el Reglamento de Ejecución (UE) 2015/1502) en relación con el grado de confianza que aporte un medio concreto de identificación electrónica sobre la identidad pretendida o declarada por una persona, teniendo en cuenta los procedimientos técnicos (prueba y verificación de la identidad, autenticación), las actividades de gestión (como la entidad que expide los medios de identificación electrónica, o el procedimiento para expedir dichos medios) y los controles aplicados. Para ello se basa en la experiencia de STORK e ISO 29115.

La obligación de reconocer los medios de identificación electrónica por parte de las Administraciones públicas se refiere únicamente a los medios de identificación que cumplan varias condiciones simultáneamente:

- (1) Hayan sido notificados a la Comisión de acuerdo con los procedimientos establecidos en la Decisión de Ejecución 2015/1984.
- (2) Cumplan los requisitos definidos en el Reglamento de Ejecución (UE) 2015/1501, en particular el conjunto mínimo de datos identificativo de la persona.
- (3) Posean un nivel de seguridad que corresponda a un nivel igual o superior al exigido para el servicio público en línea de que se trate.
- (4) Y además el organismo del sector público en cuestión emplee el nivel de seguridad “sustancial” o “alto” en lo tocante al acceso a dicho servicio en línea. Lo anterior se entiende sin perjuicio de que los Estados miembros tengan la posibilidad de reconocer medios de identificación electrónica con niveles “bajo”.

En relación con el calendario, el reconocimiento de identidades deberá encontrarse totalmente operativo el 29 de septiembre de 2018. España está ultimando la documentación para proceder a la notificación del DNLe con objeto de su aceptación en esa fecha.

2. Prestación de servicios electrónicos de confianza

Debido a que el Reglamento (UE) 910/2014 se estudió ya en el tema anterior, nos centraremos aquí en la prestación de servicios: su inicio, seguridad, listas de confianza, régimen de supervisión y sancionador.

Así, este Reglamento eIDAS introduce la regulación armónica de nuevos servicios electrónicos cualificados de confianza, adicionales a la tradicional firma electrónica, tales como el sello electrónico de persona jurídica, el servicio de validación de firmas y sellos cualificados, el servicio de preservación de firmas y sellos cualificados, el servicio de sellado de tiempo, el servicio de entrega electrónica certificada y el servicio de expedición de certificados autenticación web (para acceso a páginas mediante el protocolo seguro HTTPS), que pueden ser combinados entre sí para la prestación de servicios complejos e innovadores, reforzándose así la seguridad jurídica de las transacciones electrónicas entre empresas y particulares, y entre éstos y las Administraciones públicas.

Su artículo 3(16) define servicio de confianza como el “servicio electrónico prestado habitualmente a cambio de una remuneración, consistente en:

- a) la creación, verificación y validación de firmas electrónicas, sellos electrónicos o sellos de tiempo electrónicos, servicios de entrega electrónica certificada y certificados relativos a estos servicios, o
 b) la creación, verificación y validación de certificados para la autenticación de sitios web, o
 c) la preservación de firmas, sellos o certificados electrónicos relativos a estos servicios”.

Por otra parte, el Reglamento eIDAS establece una lista *numerus clausus* de servicios de confianza cualificados que se enmarcan en su ámbito y que se encuentran sometidos a su régimen de obligaciones y responsabilidades específicas. Así, son en total nueve los servicios electrónicos de confianza cualificados regulados y que por tanto pueden ser objeto de inclusión en la Lista de Confianza para su reconocimiento como tales a nivel comunitario:

- servicio de expedición de certificados electrónicos cualificados de firma electrónica;
- servicio de expedición de certificados electrónicos cualificados de sello electrónico;
- servicio de expedición de certificados electrónicos cualificados de autenticación de sitios web;
- servicio de expedición de sellos electrónicos cualificados de tiempo;
- servicio cualificado de entrega electrónica certificada;
- servicio cualificado de validación de firmas electrónicas cualificadas;
- servicio cualificado de validación de sellos electrónicos cualificados;
- servicio cualificado de conservación de firmas electrónicas cualificadas;
- servicio cualificado de conservación de sellos electrónicos cualificados.

Un “prestador de servicios de confianza” (anteriormente “prestador de servicios de certificación”) se define en consecuencia como una persona física o jurídica que presta uno o más servicios de confianza, bien como prestador cualificado (QTSP) o como prestador no cualificado de servicios de confianza.

Los prestadores de servicios de confianza pueden tener naturaleza pública o privada y pueden estar dirigidos al público en general o bien centrarse en una organización concreta o grupo de usuarios (administraciones, empresas o colegios profesionales).

2.1 Régimen de supervisión y control

El establecimiento de un régimen de supervisión de todos los prestadores de servicios de confianza debe garantizar unas condiciones de igualdad a nivel comunitario en cuanto a la seguridad y la rendición de cuentas en relación con sus operaciones y servicios, contribuyendo así a la protección de los usuarios y al funcionamiento armonizado del mercado interior.

El Ministerio de Energía, Turismo y Agenda Digital (MINETAD) ostenta la competencia de supervisión de los prestadores de servicios de confianza. Sus funciones principales son las siguientes:

- Supervisar a los QTSP, previa y posterior.
- Adoptar medidas en relación con los prestadores no cualificados (non-QTSP) mediante supervisión ligera, reactiva y posterior.
- Cooperar con otros organismos de supervisión de otros Estados Miembros.
- Analizar los informes de evaluación de la conformidad remitidos por los QTSP.
- Informar a otros organismos de supervisión y al público de violaciones de seguridad.
- Informar a la Comisión Europea de sus actividades.
- Realizar auditorías o solicitarlas a un organismo de evaluación de la conformidad..
- Conceder y retirar la cualificación a los prestadores.
- Requerir que los prestadores de servicios de confianza corrijan cualquier incumplimiento.

En particular, los QTSP tienen impuestas las siguientes obligaciones:

1. Los QTSP serán auditados, al menos cada 24 meses, corriendo con los gastos que ello genere, por un organismo de evaluación de la conformidad acreditado.
2. Cuando el supervisor requiera a un QTSP que corrija un incumplimiento y éste no actúe, el supervisor podrá retirar la cualificación al prestador o al servicio en cuestión.

Es oportuno hacer una mención a las entidades de evaluación de la conformidad (Conformity Assessment Bodies, o CAB). El Reglamento exige su acreditación previa ante el organismo nacional de acreditación (National Accreditation Body, o NAB) para que los informes de evaluación de la conformidad (Conformity Assessment Report, o CAR) sean aceptados por el supervisor como certificación del cumplimiento por parte del prestador de los requisitos exigidos en el Reglamento. A fecha julio de 2017, en España están acreditados por parte de ENAC los CAB siguientes:

- AENOR Internacional
- EPOCHE AND ESPRI, S.L.

No obstante, de acuerdo con los principios del mercado interior, cualquiera de los CAB acreditados en cualquier Estado miembro podría emitir un CAR sobre un prestador establecido en España.

2.2 Lista de Servicios de Confianza (TSL)

De acuerdo con la Decisión 2009/767/CE de la Comisión, el MINETAD elabora desde junio de 2010 una Lista de confianza de prestadores de servicios de certificación (TSL) correspondiente a los prestadores que expiden certificados reconocidos y que están establecidos y supervisados en España. Con la irrupción del Reglamento (UE) 910/2014, la citada Lista de Confianza ha pasado a formar parte del articulado del propio Reglamento.

La TSL contiene todos los prestadores cualificados de servicios de confianza (sello electrónico, conservación y validación de firmas y sellos, sello de tiempo, entrega electrónica y autenticación web). Las secuencias de las listas se van publicando a medida que surgen nuevos prestadores o servicios cualificados, y están oportunamente firmadas con certificados electrónicos específicos para este uso, que son comunicados a la Comisión Europea, de forma que se pueda comprobar su autenticidad e integridad. Se puede encontrar en las siguientes direcciones en sus formas HR (legible) y MP (procesable por máquinas):

- HR: (PDF/A PAdES): <https://sede.minetur.gob.es/Prestadores/TSL/TSL.pdf>
- MP: (XML XAdES): <https://sede.minetur.gob.es/Prestadores/TSL/TSL.xml>

Se muestra a continuación la portada de la última secuencia en PDF a fecha de realización de este estudio. Obsérvese su validez máxima de 6 meses:



Figura 1 Lista de confianza (PDF)

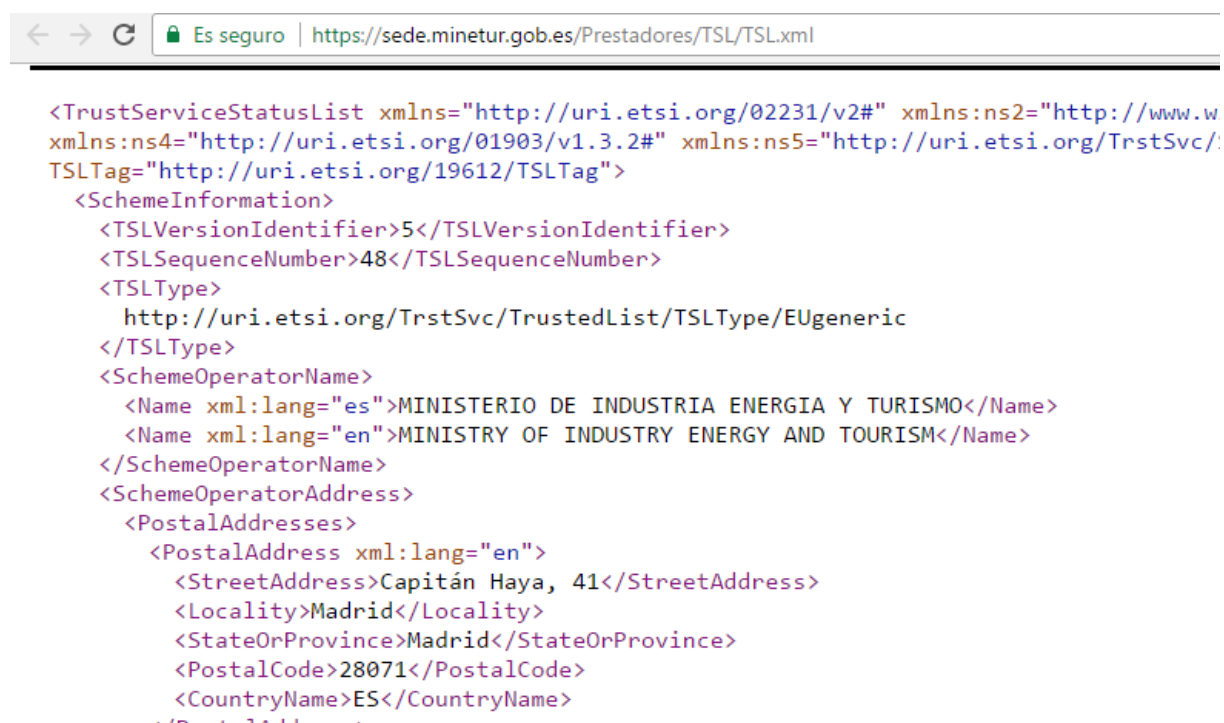


Figura 2 Lista de confianza (XML)

Por su parte, la Comisión Europea mantiene una relación de listas de los diferentes Estados miembros, agregando los enlaces a cada una de ellas en la "List of Trusted Lists" (LoTL)¹.

2.3 Inicio de la prestación de un servicio cualificado

Cuando un prestador sin cualificación desee iniciar la prestación de un servicio de confianza cualificado, presentará al MINETAD una notificación de su intención junto con un informe de evaluación de la conformidad expedido por un organismo de evaluación de la conformidad acreditado. Por su parte, el supervisor verificará si el prestador cumple los requisitos establecidos en el Reglamento. Si concluye que así es, concederá la cualificación al prestador y a los servicios de confianza que éste presta, y actualizará la Lista de Confianza (TSL) en consecuencia.

Se trata por tanto de una autorización y no de una comunicación de inicio de actividad. Una vez el servicio cualificado haya sido incorporado a la Lista de Confianza, el prestador podrá hacer uso de la "Etiqueta de confianza UE", de acuerdo con el Reglamento de Ejecución (UE) 2015/806 de la Comisión.



Figura 3 Etiqueta de confianza UE

¹ <https://ec.europa.eu/digital-agenda/en/eu-trusted-lists-certification-service-providers>

2.4 Requisitos de seguridad aplicables a los TSP y QTSP

Todos los prestadores de servicios de confianza deben estar sometidos a determinados requisitos básicos en materia de seguridad y responsabilidad:

- a. Adoptarán las medidas técnicas y organizativas adecuadas para gestionar los riesgos para la seguridad de los servicios de confianza que prestan.
- b. En un plazo máximo de 24 horas tras tener conocimiento de ellas, notificarán cualquier violación de la seguridad o pérdida de la integridad que tenga un impacto significativo en el servicio de confianza prestado o en los datos personales correspondientes.
- c. El TSP notificará también a los afectados, sin demora indebida, la violación de seguridad o la pérdida de integridad. El supervisor notificado informará al público si existe interés público.
- d. Cuando proceda, el supervisor notificado informará a los demás Estados miembros y a ENISA (*European Union Agency for Network and Information Security*).

En particular, los QTSP cumplirán los siguientes requisitos de seguridad y operación adicionales:

- a. Informarán al supervisor de cualquier cambio en la prestación de servicios de confianza cualificados, y de su intención de cesar tales actividades, para su exclusión de la TSL.
- b. Contarán con personal y, si procede, con subcontratistas, que posean los conocimientos especializados, la fiabilidad, la experiencia y las cualificaciones necesarios.
- c. Obtendrán pólizas de seguros de responsabilidad adecuadas.
- d. Informarán de las condiciones precisas relativas a la utilización del servicio.
- e. Utilizarán sistemas y productos fiables que estén protegidos contra toda alteración y que garanticen la seguridad y la fiabilidad técnicas de los procesos que sustentan.
- f. Utilizarán sistemas fiables para almacenar los datos que se les faciliten de forma verificable.
- g. Tomarán medidas adecuadas contra la falsificación y el robo de datos;
- h. Registrarán y mantendrán accesible toda la información pertinente al objeto de que sirvan de prueba en los procedimientos legales y para garantizar la continuidad del servicio.
- i. Contarán con un plan de cese;
- j. Garantizarán un tratamiento lícito de los datos personales.
- k. Mantendrán actualizada una base de datos de certificados.
- l. Registrarán la revocación de certificados en su base de datos y publicarán el estado de revocación en un plazo de 24 horas.
- m. Mantendrán un servicio gratuito OCSP o CRL para validar cada certificado incluso con posterioridad al período de validez.

2.5 Régimen de responsabilidad de los prestadores

El Reglamento establece la responsabilidad de todos los prestadores de servicios de confianza. Establece, en particular, el régimen de responsabilidad conforme al cual todos los prestadores de servicios de confianza deben responder de los perjuicios ocasionados a cualquier persona física o jurídica con motivo del incumplimiento por su parte de las obligaciones que impone el Reglamento.

2.6 Transición entre la Directiva/Ley y el Reglamento

Para garantizar la seguridad jurídica se han introducido tres medidas transitorias:

1. Los certificados **reconocidos** expedidos para las personas físicas conforme a la Directiva 1999/93/CE se considerarán certificados **cualificados** de firma hasta que caduquen.
2. Los dispositivos **seguros** de creación de firma (SSCD) con arreglo a la Directiva 1999/93/CE se considerarán dispositivos **cualificados** de creación de firma (QSCD).
3. Los prestadores de servicios de **certificación** (CSP) que emitan certificados reconocidos conforme a la Directiva 1999/93/CE presentarán un informe de evaluación de conformidad al organismo supervisor no más tarde del 1 de julio de 2017. Si no lo presentara, es excluido de la TSL en fecha 2 de julio de 2017.

2.7 Aspectos adicionales en la futura Ley de Servicios de Confianza

Ya se ha comentado que la Ley 59/2003 continúa vigente a fecha de julio de 2017, si bien se encuentra jurídicamente desplazada por el Reglamento (UE) 910/2014, por lo que los preceptos que vayan en contra del citado Reglamento son inaplicables.

Esta situación se normalizará cuando sea promulgada, a instancias del MINETAD, la nueva Ley de Servicios de Confianza, previsiblemente en otoño de 2017, cuyo objetivo es complementar el Reglamento eIDAS puesto que existen una serie de aspectos que el propio articulado del Reglamento eIDAS prevé que sean o puedan ser desarrollados a nivel nacional de la forma que cada Estado miembro considere apropiada de acuerdo con su Derecho interno, como el régimen sancionador, la cuantía de los seguros de los prestadores, el tiempo máximo de vigencia de los certificados cualificados, o la obligación de introducir en ellos el número de NIF.

3. Servicios eIDAS para las Administraciones Públicas

La Secretaría General de Administración Digital (Ministerio de Hacienda y Función Pública) tiene encomendadas varias funciones fundamentales en relación con la identidad electrónica y los servicios de confianza, destacando:

3.1 Nodo eIDAS de España

Como se comentó al comienzo del tema, existe la obligación de reconocer y aceptar los medios de identificación electrónica expedidos por los Estados miembros notificados a la Comisión Europea, para el acceso a los servicios públicos de administración electrónica a partir del 29 de septiembre de 2018.

A tal efecto, el “nodo eIDAS” de España se ha desarrollado sobre la base de lo ya implantado para el proyecto STORK (*Secure idenTity acrOss boRders linKed*) desde 2008.

Los requisitos jurídicos para el efectivo reconocimiento de identidades se han plasmado en normativa secundaria emanante del Reglamento eIDAS, destacando:

- *Decisión de Ejecución (UE) 2015/296 de la Comisión, por la que se establecen las modalidades de procedimiento para la cooperación entre los Estados miembros en materia de identificación electrónica.*

Los Estados miembros han de comunicar con una antelación de seis meses su intención de notificar un esquema de identificación, con objeto de someterse a una revisión por pares que verifique la interoperabilidad y seguridad del sistema, previo a su reconocimiento mutuo. Para ello se crea una red de cooperación entre los Estados miembros y la Comisión.

- *Reglamento de Ejecución (UE) 2015/1501 de la Comisión, sobre el marco de interoperabilidad.*

Los nodos desempeñan un papel central en la interconexión de los sistemas de identificación electrónica de los Estados miembros. Un nodo es un punto de conexión que forma parte de la arquitectura de interoperabilidad de identificación electrónica, que participa en la autenticación transfronteriza de las personas y que tiene la capacidad de reconocer y procesar o reenviar transmisiones a otros nodos permitiendo a la infraestructura de identificación electrónica nacional de un Estado miembro interaccionar con las infraestructuras de identificación electrónica nacionales de otros Estados miembros. Los requisitos técnicos y de funcionamiento incluyen en particular:

a) requisitos técnicos mínimos relacionados con los niveles de seguridad y la correlación de niveles de seguridad nacionales de medios de identificación electrónica notificados.

b) requisitos técnicos mínimos de interoperabilidad

c) el conjunto mínimo de datos de identificación de personas que representen de manera exclusiva a una persona física o jurídica. Téngase en cuenta que muchos Estados miembros no cuentan con números de identificación nacional, y los datos identificativos pueden variar enormemente entre países. Se precisa una identificación unívoca de la persona (física o

jurídica) que solicita acceder a un servicio público, por lo que se ha definido un conjunto mínimo de datos que represente a esa persona de manera exclusiva.

- d) normas de seguridad operativa comunes
- e) disposiciones para la solución de litigios.

3.2 Plataforma de servicios @firma.

La suite @firma proporciona servicios electrónicos de confianza horizontales a disposición de las Administraciones públicas. Destacan:

- **@firma:** plataforma de validación de certificados, firmas y sellos electrónicos.

Desde 2006, funciona como una plataforma de servicios de validación y firma electrónica, en cumplimiento de lo previsto en el artículo 25.1 del Real Decreto 1671/2009, en vigor, de forma libre y gratuita a todas las Administraciones públicas.

Como parte del proceso de validación de una firma o sello electrónicos, es necesario comprobar que el certificado utilizado por la persona física o jurídica no ha expirado ni ha sido revocado. Por ello es necesario verificar este extremo a través de los servicios de consulta de vigencia de los certificados que todos los prestadores que expiden certificados cualificados han de ofrecer de forma gratuita.

Así, @firma es capaz de validar todos los certificados electrónicos cualificados publicados por cualquier proveedor de servicio de confianza supervisado por el MINETAD y que como tal aparece en la Lista de Confianza publicada por el citado Ministerio. Téngase en cuenta que todas las Administraciones públicas tienen la obligación legal de aceptar estos certificados en la identificación y firma de los interesados, de acuerdo con los artículos 9.2 y 10.2 de la Ley 39/2015. Para lograr este objetivo, @firma recopila la información de la Lista de Confianza para ofrecer a sus usuarios el detalle de los certificados que valida².

Adicionalmente, el Reglamento (UE) 910/2014 impone a las Administraciones públicas de los Estados miembros el reconocimiento de los certificados cualificados que se encuentren incluidos en las Listas de Confianza del conjunto de la UE. Esto implica que @firma se ha adaptado para la validación de los certificados cualificados de 28 países europeos, en múltiples formatos de firma, incluyendo XAdES, CAdES, PAdES y ASIC, en cumplimiento de la Decisión de Ejecución (UE) 2015/1506 de la Comisión por la que se establecen las especificaciones relativas a los formatos de las firmas electrónicas avanzadas y los sellos avanzados que deben reconocer los organismos del sector público.

De aquí la importancia de que todas las Administraciones, tanto estatal, como autonómica o local, se beneficien del servicio de validación que @firma les ofrece, para poder cumplir con la legislación nacional y comunitaria. Para facilitar la integración con el servicio @firma proporciona unas librerías de integración (Integr@), que también permiten firma en servidor. Además de ofrecerse como servicio, está disponible como software para instalar por las administraciones públicas (modelo federado), con múltiples utilidades de valor añadido, entre las que se encuentran la generación y validación de firmas electrónicas en múltiples formatos.

Los últimos datos disponibles sobre @firma indican, para 2016:

- ✓ Validación de 24 prestadores cualificados de servicios de confianza españoles, así como todos los europeos, sumando más de 400 tipos de certificados validables.
- ✓ 355 millones de validaciones.
- ✓ 834 Administraciones usuarias.
- ✓ 1.480 aplicaciones usuarias.

²<https://administracionelectronica.gob.es/ctt/resources/Soluciones/190/Area%20descargas/aFirma-Anexo-PSC.pdf?idIniciativa=190&idElemento=2550>

- **TS@ Autoridad de sellado de tiempo.**

La TS@ es una Autoridad de Sellado de Tiempo puesta a disposición de todas las Administraciones Públicas con el objetivo de ofrecer los servicios de sellado, validación y resellado de sellos de tiempo, sincronizados con la hora oficial del Estado (por NTP y mediante Stratum2 con conexión GPS con el Real Observatorio de la Armada), en cumplimiento del artículo 26.2.c) de la Ley 39/2015.

Ofrece asimismo la posibilidad de validación de sellos de tiempo emitidos previamente, así como de resellado de sellos previamente emitidos. Los sellos de tiempo pueden incluirse en un documento añadidos o no a una firma electrónica.

Téngase en cuenta que, por el momento, este servicio se presta como no cualificado de acuerdo con el Reglamento (UE) 910/2014, por lo que no está incluido en la Lista de Confianza.

Los últimos datos disponibles sobre la TS@ indican:

- ✓ Más de 4 millones de sellados de tiempo mensuales.
- ✓ Más de 200 Administraciones usuarias.
- ✓ Más de 300 aplicaciones usuarias.

Adicionalmente, la suite @firma ofrece otros componentes y aplicaciones de gran utilidad, destacando:

- **Cliente @firma.** Herramienta de firma electrónica en entornos de escritorio y dispositivos móviles, que funciona en forma de applet multiformato de firma, multinavegador y multi sistema operativo integrado en una página web mediante JavaScript (en navegadores que no soportan Java el javascript del miniapplet ejecuta la aplicación Autofirma, en lugar del applet), como aplicación de escritorio (aplicación “Autofirma” o standalone), o como aplicación móvil (cliente @Firma Móvil), dependiendo del entorno del usuario. Permite realizar firmas en diferentes formatos, incluyendo CAdES, XAdES y PAdES.
- **Portafirmas.** Componente para la integración de la firma en los flujos de trabajo organizativos. Port@firmas móvil como app de complemento a Port@firmas.
- **eVisor.** Generación de copias en papel de documentos con firma electrónica. Si además lleva un CSV que permita utilizarlo como localizador en la sede del organismo, se convierte en copia auténtica de documento electrónico.
- **Integr@.** Librería de clases java, configuración y plantillas XML para integración con @firma.
- **VALIDe.** Servicio online de validación de certificados, y verificación y generación de firmas electrónicas. Entre sus destinatarios se encuentra también los ciudadanos (<https://valide.redsara.es>).
- **FIRe.** Solución que simplifica el uso y realización de firmas electrónicas de usuario al concentrar en un solo componente todos los requisitos de creación de firmas basadas tanto en certificados locales como en certificados en la nube. Dos componentes: API FIRe y servidor FIRe.

4. Infraestructura de clave pública (PKI): definición y tipos

4.1 Definición

Se denomina Infraestructura de Clave Pública (PKI) al conjunto de elementos software y hardware, procedimientos, políticas y personal cuyo objetivo es crear, almacenar, distribuir y revocar certificados digitales de clave pública, utilizados por diferentes entidades para identificarse y comunicarse remotamente de forma segura garantizando autenticidad, integridad y no repudio.

Para ello, las PKI utilizan certificados digitales que atestiguan el vínculo entre una identidad y una clave pública a través de la firma digital del emisor.

Los sistemas de PKI tienen usos variados, que dan respuesta a las necesidades de autenticación, integridad, no repudio y, opcionalmente, cifrado, esencialmente de documentos electrónicos, e-mail, así como autenticación de usuarios o servidores.

4.2 Tipos de PKI

En el mundo de Internet, donde los usuarios se comunican remotamente, se utilizan ampliamente dos tipos de PKI basadas en **certificados digitales**, que atestiguan la correspondencia entre clave pública e identidad del usuario.

Existen dos implementaciones principales de PKI:

- **PKI basadas en Autoridades de Certificación (CA) según el estándar X.509.**
- **PKI basadas en Redes de confianza.**

4.2.1 PKI basadas en Autoridades de Certificación (CA) X.509

El certificado digital sigue la recomendación ITU X.509 y es firmado digitalmente por una CA, quien centralizadamente establece el vínculo entre clave pública y titular.

En este enfoque centralizado, se establecen jerarquías de Autoridades de Certificación (CA) que actúan como tercera parte de confianza, garantizando la autenticidad de la clave pública y su asociación a una persona identificada. Para conseguirlo, la CA firma electrónicamente un documento público digital llamado certificado digital, de acuerdo con el estándar X.509v3, que contiene los datos identificativos de la persona y su clave pública.

Este modelo es adecuado para organizaciones estructuradas jerárquicamente en las que se confía en una única autoridad que expide todos los certificados. Se usa para aplicaciones personales y corporativas en relación con la firma electrónica de documentos, así como en SSL para conexiones seguras y S/MIME para cifrado de correo electrónico. Se estudiarán en detalle en un apartado posterior.

4.2.2 PKI basadas en Redes de confianza

En este caso, no se trata de certificados X.509, sino de certificados especiales que son firmados por otros usuarios a través de conexiones regidas por la confianza entre ellos.

En este modelo, al contrario que en las PKI basadas en CA reguladas, la confianza se otorga de forma descentralizada. Consiste en la creación de una red de confianza ("*web of trust*"), de forma que son los propios usuarios los que establecen relaciones y cadenas de confianza para asegurar la asociación entre claves públicas e identidades. Cada usuario toma sus propias decisiones sobre las claves públicas en las que confía, en función de su conocimiento y grado de fiabilidad que les merezcan aquellos que a su vez firman otras claves públicas.

Este es el enfoque de algunos sistemas como PGP (Pretty Good Privacy), inventado por Phil Zimmermann en 1991. Como ya se ha comentado en un tema anterior, PGP utiliza un sistema híbrido de cifrado simétrico y asimétrico. PGP fue adquirida por Symantec en 2010 e incorporado como "Symantec Encryption". No obstante, existe una versión libre OpenPGP como estándar IETF RFC 4880, implementado por ejemplo en *GnuPG* (GNU Privacy Guard).

En consecuencia, garantiza la integridad del contenido, puesto que cualquier manipulación del mensaje será detectada en el proceso de descifrado, la autenticidad del origen y el no repudio, gracias a que realiza la firma digital del mensaje (típicamente mediante RSA o DSA, computando el *hash* de la información y cifrándola con la clave privada del emisor) y una vez firmado, se cifra la

comunicación con una clave simétrica que es cifrada con la clave pública del receptor, garantizando con ello adicionalmente la confidencialidad.

En este caso, los certificados digitales de identidad son también certificados de clave pública contruidos criptográficamente para detectar cualquier manipulación, pero no son certificados X.509, sino certificados propios que siguen por ejemplo la especificación de PGP. Cualquier usuario puede firmar estos certificados para atestar que cierta clave pública corresponde a un determinado usuario en quien confía. Es decir, un mismo certificado puede estar firmado por varios usuarios, no una única vez por una CA como ocurría en X.509. Existen además cuatro grados de confianza, en función del nivel de confianza que se tenga en la clave que firma, que son: *untrusted* (los certificados firmados con esa clave son ignorados), *marginal* (se necesitan dos claves marginales para firmar con validez a una tercera clave), *complete* (una sola clave puede firmar otra con validez), *ultimate* (se posee la clave privada y todas las que se firman son válidas).

Versiones modernas de PGP permiten también la delegación de confianza, incluyendo el concepto de “trusted introducers”, que actúan de forma similar a las CA subordinadas de X.509, mientras que un “meta-introducer” tiene una función equivalente a una CA *root*. El caso de uso típico de PGP es el cifrado de e-mail, o la distribución de software como Linux, y no se utiliza en las relaciones con las Administraciones Públicas.

4.2.3 Comparativa entre PKI X.509 y PKI PGP

- Diferencias en los certificados: todos los certificados PGP son autofirmados y además contienen un número variable de firmas del resto de usuarios. Por su parte, los certificados X.509 están firmados una única vez por la CA, y el único certificado autofirmado es el raíz.
- Diferencias en la red de confianza: cualquier usuario puede crear su certificado PGP, que será firmado por otros usuarios para otorgarle confianza formándose nuevos nodos de la red, de forma que cualquier usuario puede actuar como autoridad de certificación en la práctica. Al contrario, solamente una CA puede expedir un certificado X.509, previa autorización por una RA (Autoridad de Registro).
- Diferencias en la revocación de certificados: en el caso de X.509, la firma de la CA es lo que da validez al certificado, y es por tanto únicamente la CA la que puede de forma efectiva revocarlo en caso necesario, y comunicarlo vía CRL u OCSP. Al contrario, en PGP el usuario puede revocar su certificado.

4.2.4 Otras soluciones

Otras soluciones mencionables que han tratado de solventar la cuestión del intercambio de claves públicas, al tiempo que evitar los problemas inherentes a las infraestructuras de clave pública son:

- **Criptografía basada en identidad** (*Identity-Based Cryptography*, IBC), en la que un tercero de confianza opera un generador de claves o PKG (*Private Key Generator*), que crea las claves públicas y privadas de los usuarios a partir de claves maestras y de la identificación del usuario con cierta información única del mismo (por ejemplo, una dirección de correo electrónico). Introducida por Shamir en 1984.
- **Criptografía sin certificados** (*Certificateless Cryptography*), que hace uso de un KGC (*Key Generator Center*) para crear una clave parcial, generándose la clave privada completa a partir de la citada clave privada parcial y un valor generado aleatoriamente por el usuario. Trata de evitar el problema del *key escrow*, o depósito de claves para su utilización por un tercero autorizado que pudiese acceder a las claves y por tanto a la información.
- **Simple public key infrastructure** (*SPKI*). Solución experimental que no se llegó a desplegar en la que no se utilizaba la noción de “confianza” sino de “autorización”.
- **PKI basada en Blockchain**. Una de las posibles aplicaciones prácticas de Blockchain sería la creación de una PKI descentralizada y distribuida. Ya hay experiencias en marcha, como

EMCSSL de Emercoin, en la que los usuarios generan sus propios certificados SSL sin necesidad de una autoridad central.

5. Componentes principales de una PKI X.509

Los elementos esenciales se muestran en la figura siguiente:

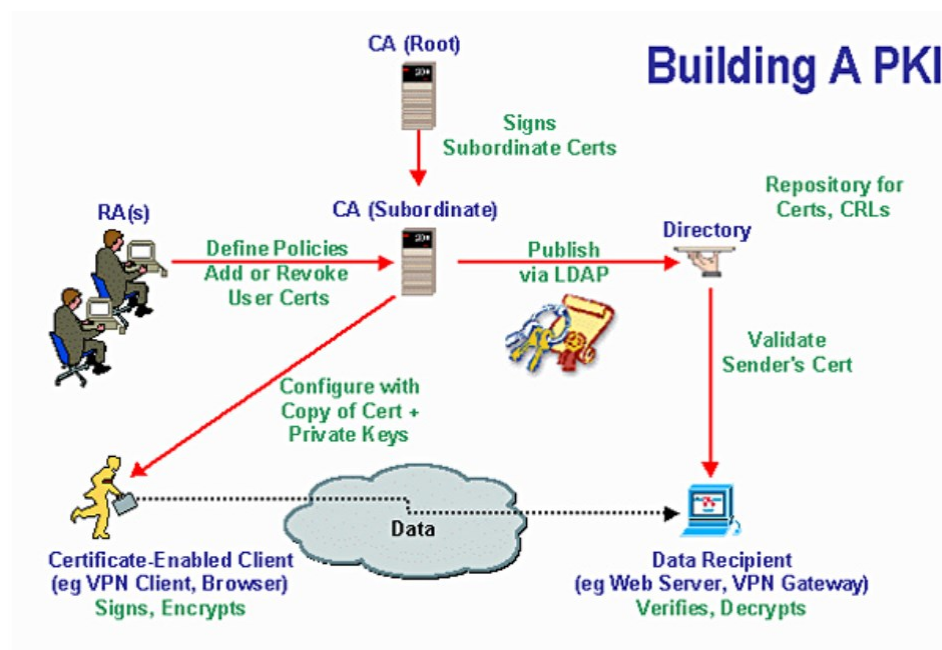


Figura 4 Elementos esenciales de una PKI

5.1 Autoridad de certificación (Certification Authority, CA)

La CA es una tercera parte de confianza (TTP) que expide, gestiona y revoca los certificados digitales. Los usuarios confían en el vínculo que establece la CA entre identidades y claves públicas al firmar los certificados con su propia clave privada.

Existen diferentes niveles de CA, en una estructura jerárquica, situándose en la cúspide la “CA root” (certificado autofirmado), que firma con su clave privada los certificados de las “CA subordinadas” (o intermedias), que a su vez firman con sus claves privadas los certificados finales o de usuario (personas, servidores...), conformando el conjunto lo que se conoce como “cadena de certificación”.

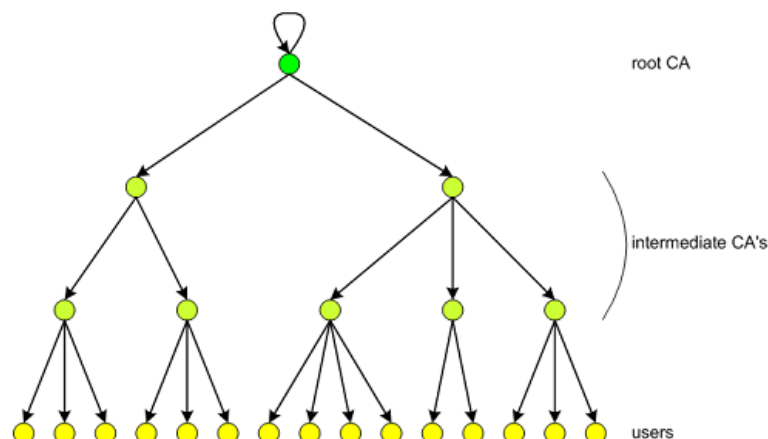


Figura 5 Jerarquía en una PKI

Naturalmente, los certificados de las CA subordinadas y el certificado raíz son públicos, de forma que el conjunto de la cadena de certificación pueda ser validado a la hora de verificar una firma realizada con un certificado final. Se deben descargar de directorios X.500 o de las páginas web de los prestadores, e instalar en el dispositivo de la parte usuaria que valida la firma. Por ejemplo:

Certificado raíz del DNle. “Emisor” y “sujeto” coinciden, al ser un certificado autofirmado.

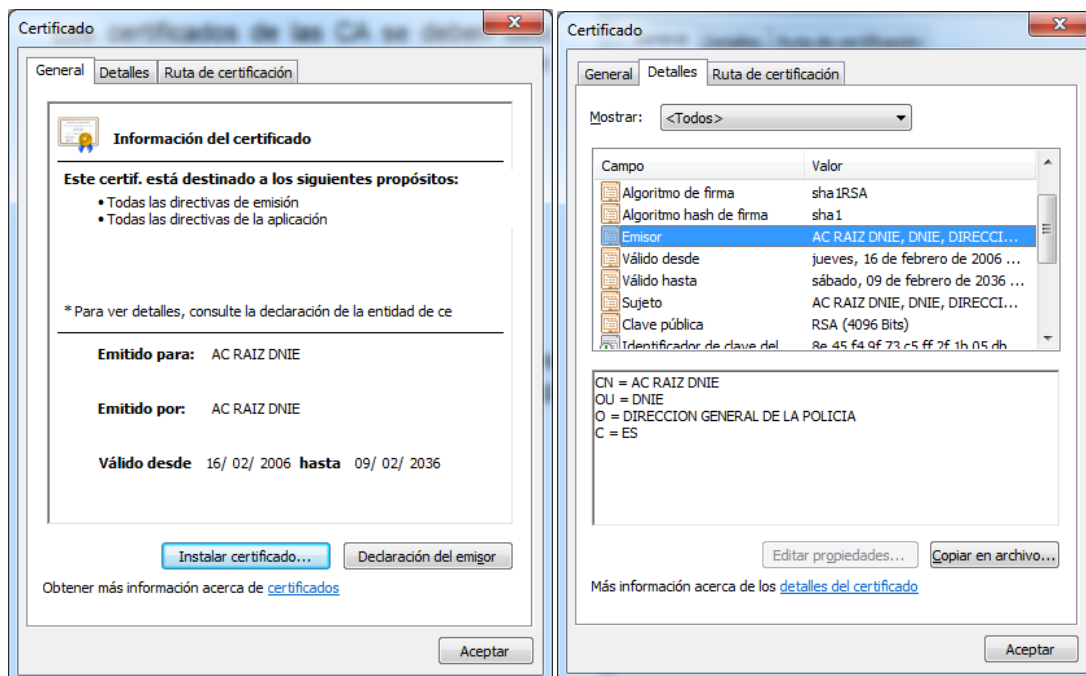


Figura 6 Certificado raíz del DNle

Certificado de una CA del DNle. Es firmado por el certificado raíz. Existen varias CA intermedias.

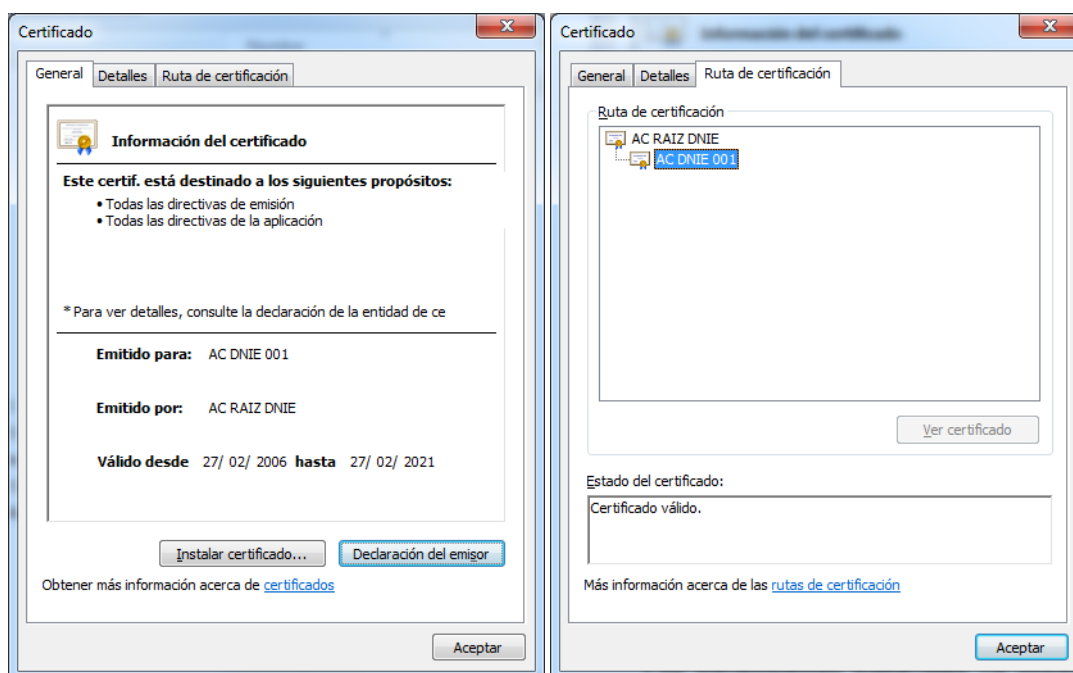


Figura 7 Certificado de una CA del DNle

Certificado de usuario del DNle. Obsérvese que es firmado por un certificado de CA subordinada.

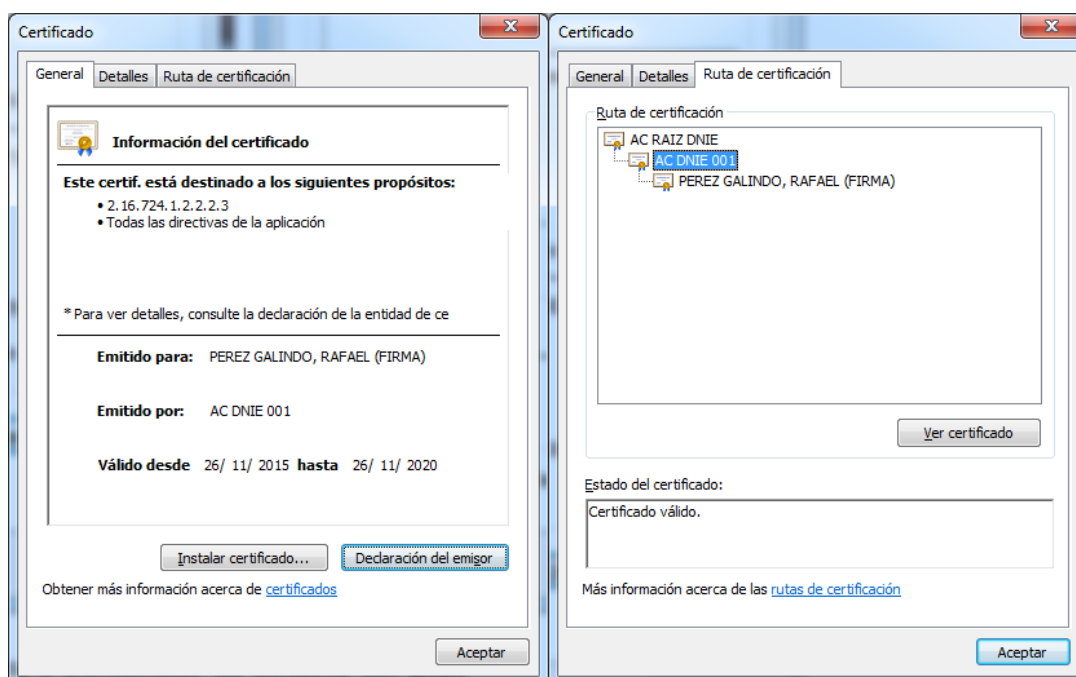


Figura 8 Certificado de usuario del DNle

Los navegadores habituales ya poseen precargados la mayoría de los certificados de las CA de los prestadores de servicios de confianza que emiten certificados de autenticación de sitios web (típicamente certificados SSL) que consideran seguros. Obsérvese que los prestadores españoles suelen estar en los primeros lugares de la lista al mostrarse alfabéticamente, debido a la traducción "Autoridad de Certificación" o "AC". Para poder ser cargados en los navegadores y que la utilización de HTTPS y el candado o barra verde otorguen confianza al sitio web, estos prestadores han de demostrar a los navegadores que cumplen determinadas normas y reglas que publica el CAB/Forum, en procesos específicos para cada uno de ellos (Firefox, IE, Chrome, Safari,...).

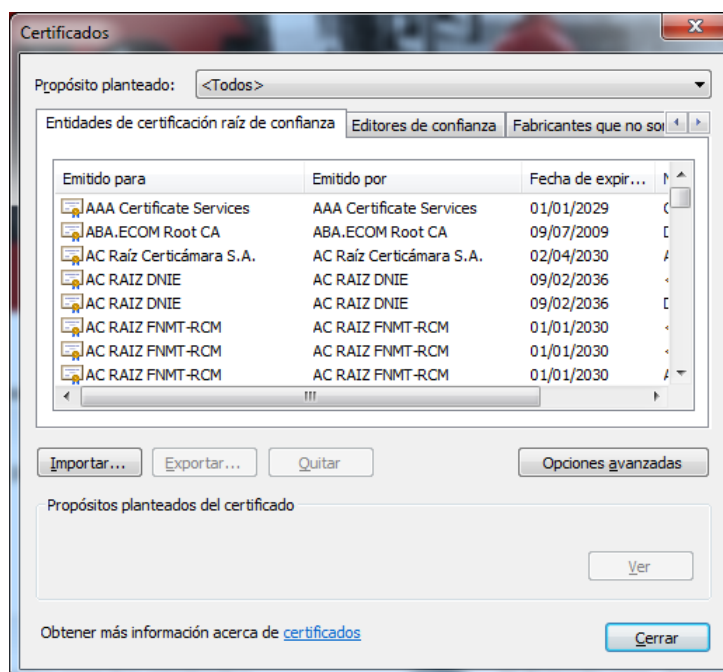


Figura 9 Certificados de confianza de un navegador

Y también aquellos en los que no se confía (obsérvese el tristemente famoso caso “Diginotar”³):

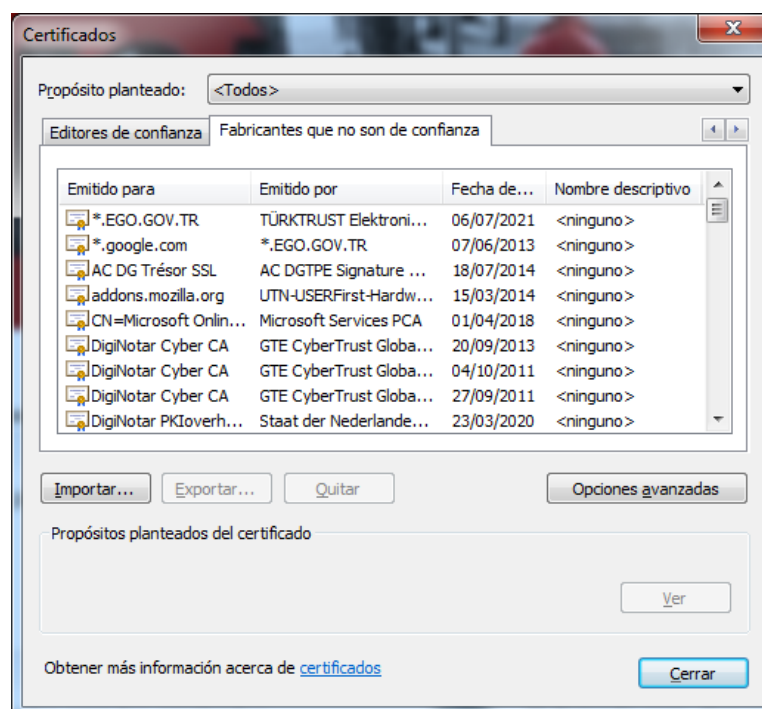


Figura 10 Certificados no de confianza de un navegador

5.2 Autoridad de registro (Registration Authority, RA)

De forma previa a la expedición del certificado, su función es verificar la identidad del titular, de forma que la Autoridad de Certificación (CA) pueda asociarla con un par de claves y generar el certificado electrónico. También se encarga de recibir y procesar solicitudes de revocación de certificados.

Una vez realizadas las comprobaciones oportunas, la RA envía a la CA la información pertinente para la expedición del certificado. El prestador cualificado de servicios de confianza ha de verificar la identidad y atributos de la persona física o jurídica a la que se expide el certificado cualificado:

- Por comparecencia presencial de la persona física, o representante de la persona jurídica;
- Remotamente, a través de medios de identificación electrónica obtenidos presencialmente y que posean un nivel de seguridad sustancial o alto;
- Por medio de certificados cualificados de firma o de sello;
- Por medio de otros medios equivalentes a presencia física reconocidos a nivel nacional, acreditados por un organismo de evaluación de la conformidad.

5.3 Autoridad de validación (Validation Authority, VA)

Su función es prestar un servicio de comprobación de la validez de un determinado certificado, es decir, si ha sido revocado antes de su caducidad.

Para ello, se utilizan servicios de directorio y mecanismos como CRL (*Certificate Revocation List*) y OCSP (*Online Certificate Status Protocol*) estudiadas en el tema anterior, mediante las cuales un tercero puede consultar el estado de vigencia de la validez de un determinado certificado, y confirmar que no ha sido revocado.

³<http://www.computerworld.com/article/2511297/security0/diginotar-dies-from-certificate-hack-caper.html>

5.4 Proveedores de CA

Existen diferentes proveedores de tecnologías de CA, relacionándose a continuación los más extendidos en el mercado:

- **Safelayer:** tecnología española, líder en el mercado nacional.
- **Entrust:** líder mundial, proveniente de Estados Unidos.
- **EJBCA:** software libre, basado en Java.
- **Microsoft** PKI and Active Directory Certificate Services.

5.5 Impacto de la computación cuántica

El desarrollo de la computación cuántica puede acabar resolviendo varios de los problemas matemáticos, como la factorización de números primos, en los que se basa la criptografía asimétrica utilizada masivamente en las PKI y que viene sirviendo para proteger la seguridad y la privacidad de los usuarios.

Organismos como ETSI están ya trabajando en nuevos sistemas de criptografía que no sean vulnerables a la computación cuántica, lo que se conoce como “*Quantum-safe cryptography*” (QSC).

5.6 PKI en la arquitectura de Internet

La necesidad de reforzar la seguridad de los protocolos de Internet ha llevado en los últimos años a la utilización de infraestructuras de clave pública en dos aspectos fundamentales, que se analizarán brevemente a continuación:

- **DNSSEC**

La falta de seguridad en las especificaciones originales del Sistema de Nombres de Dominio (Domain Name System, DNS) obligó al IETF a definir un conjunto de extensiones para mitigar ataques como *DNS poisoning* autenticando el origen de las resoluciones de dominios así como su integridad, al tiempo que garantizaba la compatibilidad con el tradicional DNS (al contrario de lo que ocurre con IPv6 e IPv4).

DNSSEC está basado en criptografía de clave pública o asimétrica, ya que se firman digitalmente las respuestas a las consultas de DNS. El ancla de confianza o *trust anchor* es la raíz del DNS, que fue firmada y publicada el 15 de julio de 2010, tras una ceremonia de claves en la que participaron ICANN (como operador de las funciones IANA, gestiona la *Key Signing Key* o KSK), Verisign (como operador de la raíz del DNS, gestiona las *Zone Signing Key* o ZSK, más cortas que la KSK pero con renovación más frecuente), su entonces supervisor (el Departamento de Comercio de los EE.UU.), y 21 voluntarios de la comunidad de Internet como depositarios de porciones de la clave.

La situación ha cambiado desde el 30 de septiembre de 2016, debido a la finalización del proceso conocido como “Transición IANA” por el cual el Gobierno de los EE.UU. renunció a la supervisión de las funciones IANA (números (direcciones IP, sistemas autónomos BGP), protocolos, nombres de dominio) ejecutadas por ICANN, en favor de la comunidad global *multistakeholder*. La refundación de ICANN ha supuesto la creación de la filial Public Technical Identifiers (PTI) para la gestión de las funciones IANA, y desde entonces la delegación y firma de dominios ya no ha de ser aprobada por los EE.UU.

- **RPKI**

DNSSEC sirve para evitar respuestas DNS maliciosas, pero ¿qué ocurre con los anuncios de redes IP en el enrutamiento por BGP? ¿Cómo saber que la información de enrutamiento es correcta para la transmisión de información entre routers hasta el titular legítimo? Téngase en cuenta que la información de enrutamiento puede ser incorrecta por errores de configuración o por motivos

intencionados⁴. La solución al “secuestro de ruta” (*route hijacking*) es *Resource Public Key Infrastructure* (RPKI) que establece una correspondencia entre los prefijos que identifican redes IP y los números de sistema autónomo (AS) que utiliza Border Gateway Protocol (BGP) para enrutar los paquetes.

Así, en la RPKI, cada RIR (RIPE NCC; AFRINIC; LACNIC; APNIC; ARIN) posee una raíz autofirmada con la que emite certificados X.509 a cada titular de un conjunto de direcciones IP. A los certificados se han añadido extensiones para incluir el direccionamiento IP y el número de sistema autónomo de BGP correspondiente, pero no información identificativa del titular. De esta forma, cada titular puede emitir atestados de autenticidad del origen de un anuncio de routing (*Route Origination Authorization*, o ROA) firmados con su propio certificado.

Tanto los certificados como los ROA se publican en repositorios públicos, y así es posible generar listas que contengan una relación de los Sistemas Autónomos de BGP y las redes que están autorizados a anunciar en Internet. Los fabricantes de routers más importantes (Juniper, Cisco) ofrecen soporte para RPKI en todas sus plataformas, comprobando en sus procesos de routing que los anuncios BGP son correctos. El resultado puede ser *valid*, *invalid* o *unknown*, lo que desencadenará las acciones oportunas.

6. Mecanismos de identificación y firma

6.1 Almacenamiento seguro de claves privadas

En relación con el almacenamiento de las claves privadas, la seguridad es fundamental para garantizar la confianza en el sistema, así como los efectos jurídicos de las firmas o sellos creados (básicos, avanzados o cualificados), de acuerdo con el Reglamento (UE) 910/2014.

En relación con el almacenamiento de claves en software, por ejemplo cuando se guarda un certificado electrónico en un dispositivo personal, sea en un ordenador, tablet, o móvil, se debe tener en cuenta que un atacante podría provocar excepciones de memoria en el sistema para obtener la clave privada, incluso si ésta se encuentra cifrada. En términos generales, se puede afirmar que la criptografía basada en hardware (*tamper resistant*) es más segura que la basada en software, ya que todas las operaciones criptográficas se realizan en el propio dispositivo, del que nunca salen las claves hacia el sistema operativo o la memoria.

En este sentido, se ha producido una importante evolución tecnológica desde un punto de vista del hardware. No tiene sentido ya pensar únicamente en tarjetas inteligentes, aunque mantienen un lugar sustancial, porque han ido apareciendo gran variedad de dispositivos capaces de albergar claves y generar firmas y sellos electrónicos.

Por supuesto los dispositivos deben ir acompañados de medidas de seguridad físicas, perimetrales, de red, procedimentales y organizativas apropiadas para minimizar el riesgo de ataques.

6.1.1 Tarjetas inteligentes

El término tarjeta inteligente (*smart card*) o tarjeta con circuito integrado (TCI) se utiliza para describir una clase de dispositivos con forma de tarjeta, bien del tamaño de una tarjeta de crédito o más pequeña (tipo SIM). Este circuito puede ser de solo memoria o contener un microprocesador (CPU) con un sistema operativo que le permite una serie de tareas como almacenar o cifrar información, leer y escribir datos, y que en consecuencia es capaz de proveer ciertas funcionalidades de seguridad, como la autenticación o almacenamiento seguro.

Las tarjetas con circuito integrado se regulan en la **norma ISO 7816**:

⁴ <https://www.cnet.com/news/how-pakistan-knocked-youtube-offline-and-how-to-make-sure-it-never-happens-again/>

- 7816-1: Características físicas.
- 7816-2: Dimensiones y ubicación de los contactos.
- 7816-3: Protocolos de interfaz eléctrica y de transmisión.
- 7816-4: Organización, seguridad y comandos para el intercambio de información
- 7816-5: Registro de la solicitud de los proveedores.
- 7816-6: Interoperabilidad en los elementos de datos para el intercambio.
- 7816-7: Interoperabilidad en los comandos de la tarjeta (SCQL).
- 7816-8: Comandos para operaciones de seguridad.
- 7816-9: Comandos para la gestión de la tarjeta.
- 7816-10: Señales electrónicas para operación síncrona.
- 7816-11: Verificación de la identidad personal a través de métodos biométricos.
- 7816-12 Tarjetas con contactos. Interfaz eléctrica USB y procedimientos operativos.
- 7816-13: Comandos de administración de aplicaciones en entornos multi-aplicación.
- 7816-15: Aplicación de información criptográfica.

Se pueden clasificar en función de su capacidad:

- **Tarjeta de memoria:** únicamente tiene capacidad de almacenamiento de información. No son tarjetas inteligentes estrictamente hablando. Su aplicación fundamental es la identificación y control de acceso, así como aplicaciones de prepago. Mantiene su contenido sin necesidad de energía externa. La memoria puede ser EPROM o EEPROM.
- **Tarjeta microprocesadora:** su estructura es análoga a la de un ordenador. El chip está formado por un microprocesador y memoria (RAM, ROM, EPROM, EEPROM...).
- **Tarjeta criptográfica:** tiene capacidad de ejecutar operaciones criptográficas para realizar firmas digitales y cifrar la información, así como de albergar certificados digitales y claves privadas que no se pueden extraer de la tarjeta.

Desde el punto de vista de la conectividad y el interfaz que ofrecen, hay tarjetas sin contactos (*contactless*), tarjetas de contactos e híbridas:

- **Tarjetas de contacto.** Disponen de unos contactos metálicos visibles y debidamente estandarizados. Los protocolos de comunicación incluyen T=0 (transmisión a nivel de carácter) y T=1 (transmisión a nivel de bloque), según ISO/IEC 7816-3. En las tarjetas de contacto, las conexiones eléctricas se unen al microprocesador mediante hilos de oro formando lo que se conoce como el micromódulo. El micromódulo está formado por 8 contactos que van desde el C1 al C8 y puede estar localizado tanto en el anverso como en el reverso de la tarjeta. Estos contactos tienen la siguiente funcionalidad:

C1: Alimentación (VCC)	C5: Masa (GND)
C2: Contacto de inicialización (Reset)	C6: Tensión de programación (Vpp)
C3: Señal de reloj (CLK)	C7: Comunicación de datos (I/O)
C4: Reservada para futuros usos	C8: Reservada para futuros usos



Figura 11 Microprocesador

Los chips de las tarjetas son los mismos que los utilizados en las SIM telefónicas, aunque programadas de forma diferente:

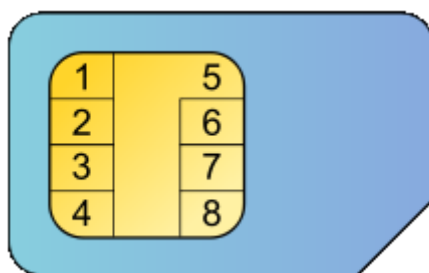


Figura 12 SIM

1. VCC (alimentación)
2. RST(reset)
3. CLK(clock)
4. D+(USB inter-Chip)
5. GND (tierra)
6. SWP
7. I/O (Input/Output)
8. D-(USB inter-Chip)

- **Tarjetas sin contacto o de proximidad (*contactless*).** Operan sin que haya que insertar la tarjeta en ningún dispositivo, sino que mediante etiquetas RFID el chip se comunica por inducción con el lector de tarjetas a una tasa de transferencia de 106 a 848 Kbit/s. Son especialmente adecuadas para aplicaciones donde priman la velocidad y la facilidad de uso, como por ejemplo en los medios de transporte, ya que la tarjeta de proximidad funciona a una distancia entre 5 y 10 cm. Tampoco tienen una fuente de alimentación interna.

El estándar **ISO 14443 (RFID)** define la transmisión en una tarjeta de proximidad utilizada para identificación y pagos. El sistema RFID utiliza un lector con un microcontrolador incrustado y una antena que opera a 13,56 MHz. El lector mantiene a su alrededor un campo electromagnético de modo que al acercarse una tarjeta al campo, ésta se alimenta eléctricamente de esta energía inducida y puede establecerse la comunicación lector-tarjeta.

El estándar ISO 14443 consta de cuatro partes y se describen dos tipos de tarjetas: tipo A y tipo B. Las tarjetas MIFARE cumplen con las partes 1, 2 y 3 de tipo A. MIFARE es una tecnología de tarjetas inteligentes sin contacto (TISC), de las más ampliamente instaladas en el mundo.

Mención especial merece la tecnología **NFC (Near Field Communication)**, conjunto de estándares basados en ISO/IEC 14443 y FeliCa, incluyendo ISO/IEC 18092 para comunicación entre dispositivos móviles vía radio a pequeña distancia (máximo teórico 4 centímetros). Utiliza una frecuencia de 13,56 MHz, y consigue una tasa de transferencia de 106, 212 y 424 kbit/s. Se consigue bidireccionalidad en la comunicación entre dispositivos activos, aunque también puede ser unidireccional mediante lectura de "*tags*" no alimentados. Sus aplicaciones típicas son pago sin contactos, accesos, juegos... Se ha popularizado desde la versión 4 de Android.

NFC se diferencia de Bluetooth en que es más lento en cuanto a tasa de transferencia, pero requiere mucha menos potencia y es muy rápido en cuanto a la velocidad de conexión automática. Su frecuencia de trabajo es mucho menor así como la extensión del campo de conectividad, lo que reduce posibilidad de interceptación. No obstante, existe preocupación por la seguridad de NFC, lo que ha llevado a recomendar utilizar SSL adicional en las aplicaciones que lo utilicen.

NFC es compatible con RFID. El NFC Forum es la asociación industrial que impulsa su utilización.

- **Tarjetas híbridas y duales** (*combicards*). Buscan aunar las ventajas de ambas en una sola tarjeta multiaplicación. Estas tarjetas funcionan de ambas formas según las necesidades (especialmente de seguridad) que presente la aplicación para la que se destinan.

Una tarjeta híbrida es una tarjeta sin contacto (*contactless*) a la cual se le agrega un segundo chip de contacto. Ambos chips pueden ser o chips microprocesadores o simples chips de memoria. El chip sin contacto es generalmente usado en aplicaciones que requieren transacciones rápidas. Por ejemplo el transporte, mientras que el chip de contacto es generalmente utilizado en aplicaciones que requieren de alta seguridad como las bancarias.

Una tarjeta de interfaz dual es similar a la tarjeta híbrida en que la tarjeta presenta ambas interfaces con y sin contacto. La diferencia más importante es el hecho de que la tarjeta de interfaz dual tiene un solo circuito integrado.

Por otro lado, desde el punto de vista del formato, según ISO 7816 parte 1 se pueden clasificar en:

- **ID 000:** tarjetas SIM (*Subscriber Identity Module*) para teléfonos móviles/módems y tarjetas SAM (*Security Access Module*) utilizadas para autenticación criptográfica.
- **ID 00:** tamaño poco utilizado.
- **ID 1:** tamaño equivalente a una tarjeta de crédito.

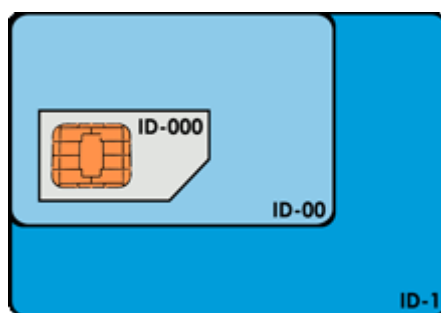


Figura 13 Formatos de tarjeta

Por su parte, las tarjetas SIM han sufrido una progresiva miniaturización con la definición del estándar ETSI TS 102 221, que introdujo los conceptos Micro-SIM (Mini-UICC, ETSI TS 102 221) y Nano-SIM.

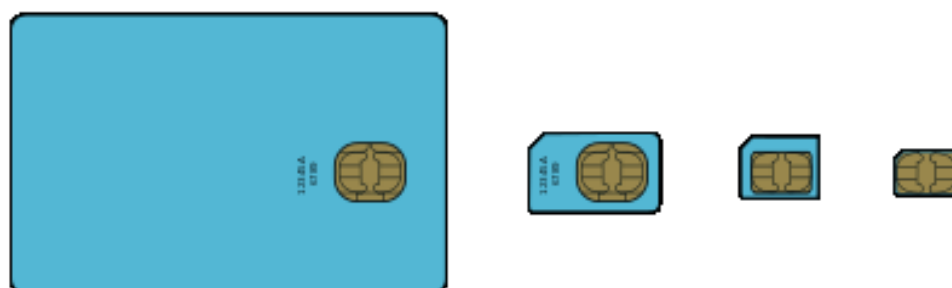


Figura 14 Formatos de SIM

Estructura de la tarjeta

La memoria de trabajo suele ser una combinación de memoria EPROM y EEPROM (o flash) y a su vez se divide en diferentes zonas:

- Zona secreta: almacena las claves del emisor de la tarjeta, del usuario y las de cifrado..
- Zona de trabajo: es susceptible de ser escrita, leída o borrada.
- Zona de libre lectura.
- Zona confidencial: exige una clave para poder acceder a su contenido.

Seguridad de la tarjeta

La tarjeta inteligente, a diferencia de la de banda magnética, es un elemento activo en cuanto a la seguridad. Esto significa que la propia tarjeta dificulta su manipulación y comprueba los derechos de acceso de la entidad que pretende hacer uso de ella. De hecho, es posible que el titular de la tarjeta tenga derecho a leer sus datos, pero que no pueda modificarlos.

Un mecanismo habitual de seguridad consiste en que la introducción de tres claves de usuario o una clave de emisor errónea, bloqueen la tarjeta. El mecanismo de rehabilitación requiere que se introduzcan de forma simultánea las claves correctas del emisor y del usuario.

La seguridad física

Se basa en las características físicas y lógicas del propio chip, así como en las inherentes a su proceso de fabricación. Las principales son:

- Las memorias integradas son resistentes a los campos magnéticos y electromagnéticos, lo que no ocurre con las tarjetas de banda magnética.
- Existen bits de testigo en las memorias que permiten detectar el uso no autorizado de la tarjeta. De hecho, cada vez que se alimenta la tarjeta se leen y si su contenido se ha modificado o no es consistente, se considera que ha existido un intento de violación de la seguridad de la tarjeta, obrando en consecuencia.
- Las memorias utilizadas se borran con la radiación ultravioleta, de esta forma, si se abre el chip para explorarlo se perderá su contenido.
- La memoria no adopta una distribución lineal, lo que dificulta una exploración de su contenido.
- Se garantiza un consumo aleatorio de la tensión, independiente de la operación que se esté realizando. De esta forma no puede obtenerse ninguna información sobre el funcionamiento interno a partir del análisis de su consumo.
- El número de contactos con el exterior se limita a los establecidos en la norma (6 activos). Los puntos de prueba son destruidos durante el proceso de fabricación.
- La propia tarjeta controla el voltaje que utiliza.

La seguridad lógica

Se basa en las funciones que se incluyen dentro del sistema operativo. Estos sistemas pueden ser de propósito general (para desarrollar sobre él cualquier tipo de aplicación) o específicos para un tipo de aplicación (por ejemplo acceso a redes telefónicas), pero en cualquier caso las funciones encaminadas al tratamiento de los problemas de seguridad son de las más cuidadas por la naturaleza misma de su función.

Las principales funciones son:

- Autenticación: Permite a un terminal o sistema remoto garantizar que está dialogando con una tarjeta autorizada.
- Identificación: Permite verificar que la tarjeta está siendo utilizada por el usuario autorizado. Es la propia tarjeta la que verifica el código introducido por el usuario (PIN) o sus datos biométricos con los de referencia.
- Firma electrónica: La propia tarjeta es capaz de firmar cualquier documento sin que la clave privada salga del chip. Es su propio microprocesador el que cifrará con la clave privada del usuario el hash asociado al documento que se firma.
- Transporte de las claves: Las claves secretas no salen de la tarjeta y se almacenan en una zona de memoria no accesible desde el exterior. No hay, por tanto, transporte de claves.
- Confidencialidad: La propia tarjeta puede realizar las funciones de cifrado necesarias, utilizando tanto algoritmos simétricos como asimétricos.

El software de la tarjeta y de los sistemas con los que se comunica

- **PC/SC (*Personal Computer/Smart Card*)**

No obstante, ni la ISO 7816 ni las especificaciones particulares establecen elementos de interoperabilidad entre aplicaciones como serían APIs independientes de los dispositivos, herramientas de desarrollo o compartición de recursos. Por ello en mayo de 1996 se creó el **PC/SC Workgroup**, una alianza formada por importantes fabricantes de ordenadores y tarjetas inteligentes cuyo objetivo principal ha sido el desarrollar especificaciones que resolviesen los problemas de interoperabilidad entre las tarjetas y los terminales y la cooperación entre el terminal y el sistema operativo. En diciembre de 1997, el grupo publicó la primera versión de las especificaciones. La especificación, basada en los estándares ISO 7816, se extiende desde las características físicas de las tarjetas y los terminales hasta la capa de programación de aplicaciones. Estas especificaciones han tenido un amplio soporte por parte de la industria y se espera que en el futuro se conviertan en un estándar independiente.

- **OCF (*OpenCard Framework*)**

Especificado por el grupo de empresas OpenCard. Este entorno intenta proporcionar un diseño orientado a objetos fácilmente extensible y modular. El consorcio OpenCard publica el API y proporciona una implementación de referencia en Java. Existe un adaptador para que OCF trabaje sobre PC/SC.

- **JavaCard**

Permite ejecutar de forma segura pequeñas aplicaciones Java (applets) en tarjetas inteligentes y similares dispositivos empotrados. Esta tecnología se usa ampliamente en las tarjetas SIM (utilizadas en teléfonos móviles GSM) y en tarjetas monedero electrónico. Las principales características de esta tecnología son la portabilidad y la seguridad.

Es destacable el estándar **EMV (*Europay MasterCard VISA*)**. EMV es un estándar de interoperabilidad de tarjetas inteligentes y terminales de punto de venta (TPV), para la autenticación de pagos mediante tarjetas de crédito y débito. EMV define la interacción entre las tarjetas y los terminales a nivel físico, eléctrico, de datos y de aplicación, basándose en gran medida en ISO 7816.

Comunicación entre un ordenador personal y una tarjeta inteligente

En la comunicación entre un PC y una tarjeta intervienen los siguientes elementos:

- driver del lector
- librerías del sistema
- librerías criptográficas
- aplicaciones
- usuarios

Hay dos tipos diferentes de librerías criptográficas:

1. CSP (*Cryptographic Service Provider*)

Un CSP es una librería software que implementa el interface de programación del sistema criptográfico o CSPI (*Cryptographic System Programming Interface*). Microsoft Windows dispone de una API llamada CryptoAPI para la gestión de los CSP.

Los CSP implementan todas las funciones necesarias para realizar cifrado, descifrado, firma electrónica, etc. de un motor criptográfico. Estos motores se clasifican en dos grupos: CSP software y CSP basado en tarjeta inteligente. Normalmente será necesario desarrollar un CSP específico para cada tarjeta, ya que éstas utilizan comandos de comunicación diferentes. Cada CSP debe estar firmado electrónicamente por Microsoft ya que éste verifica la firma cada vez que carga el CSP.

Los CSP se utilizan para trabajar a alto nivel con las tarjetas a nivel criptográfico y de gestión de certificados a diferencia de la WinSCard que se utiliza para enviar comandos a bajo nivel.

2. PKCS#11 (*Public-Key Infrastructure Standard*)

PKCS#11 es de la familia de los estándares de facto llamados *Public-Key Cryptography Standards*, publicado por RSA Laboratories. Define una API independiente de la plataforma para tokens criptográficos, como los Módulos de Seguridad Hardware (HSM) y las tarjetas inteligentes. Esta API define los tipos de objetos criptográficos más utilizados (diferentes tipos de claves, certificados y algoritmos de cifrado y firma) y todas las funciones necesarias para usarlos, crearlos/generarlos, modificarlos y borrarlos.

Esta API es independiente de la plataforma, así que se pueden implementar un módulo PKCS#11 tanto para Microsoft Windows como para sistemas basados en Unix (diferentes distribuciones de Linux, Mac OS X o Solaris). La implementación más común de esta API la proporciona el proyecto de código abierto OpenSC. Además, OpenSC proporciona un conjunto de herramientas y aplicaciones, así como otras interfaces para trabajar con tarjeta inteligente.

Certificación de las *smartcards* como dispositivos cualificados de creación de firma (SSCD)

El anexo II del Reglamento (UE) 910/2014 establece los requisitos aplicables a los dispositivos cualificados de creación de firma y sello (QSCD).

En desarrollo de lo anterior, el anexo I de la Decisión de ejecución (UE) 2016/650 fija las normas de evaluación de la seguridad que se aplican a la certificación de los QSCD, aplicable por el momento a la firma o sello electrónicos creados en un entorno gestionado por el firmante.

Así, esta Decisión deroga la vetusta Decisión 2003/511/CE de la Comisión, que imponía la certificación de las tarjetas de acuerdo con el estándar CEN CWA 14169.

Los estándares aplicables serán:

- ISO/IEC 15408 (Criterios de evaluación para la seguridad de la TI)
- ISO/IEC 18045:2008 (Metodología para la evaluación de la seguridad de la TI)
- EN 419 211 (Perfiles de protección para los dispositivos seguros de creación de firma)

Las tarjetas certificadas de acuerdo con estas normas como dispositivos cualificados por parte de los organismos de certificación de cada Estado miembro (CCN en España) serán comunicadas a la Comisión Europea para su publicación en la lista de dispositivos cualificados⁵, junto con aquellos que fueron certificados de acuerdo con la Directiva y gozan de la medida transitoria que les convierte en dispositivos cualificados hasta que su certificación caduque.

6.1.2 Pads

Los pads capturan digitalmente las firmas realizadas por los usuarios. Se pueden integrar con software, hardware, o aplicaciones.

Existe una gran variedad y evolución de estos dispositivos, con los que se puede generar firma digitalizada biométrica que puede ser de utilidad en determinados entornos, típicamente comercios o el sector de la salud.

Diferentes factores biométricos como la velocidad, presión y ángulo de escritura son almacenados por el sistema para prestar seguridad a la transacción y evitar el repudio en la medida de lo posible.

⁵ <https://ec.europa.eu/futurium/en/content/compilation-member-states-notification-sscds-and-qscds>

Combinados con mecanismos de *hashing*, podrían dar lugar a sistemas de firma avanzada en determinadas circunstancias, si se garantizase el control exclusivo del firmante, la integridad de los datos firmados y se utilizasen medidas para garantizar que lo que el firmante visualiza es lo que realmente firma (*"what you see is what you sign"*), de forma que se evitase el repudio. Una de las soluciones que se suele utilizar es la firma o sellado de la información biométrica por parte de un prestador de servicios de confianza, pero se debe tener en cuenta que no constituye una firma o sello del propio usuario.

6.1.3 Token criptográfico

Es un dispositivo utilizado típicamente para la autenticación de usuarios en sistemas remotos. Los *tokens* electrónicos se usan para almacenar claves criptográficas y datos biométricos, como las huellas digitales. Algunos diseños se hacen a prueba de alteraciones, otros pueden incluir teclados para la entrada de un PIN.

Existen dos tipos fundamentales de *token*:

- Generadores de contraseñas dinámicas de un solo uso u "OTP" (*One Time Password*)



Figura 15 Generador de OTP

- *Tokens* USB, los cuales permiten almacenar contraseñas y certificados y, además, llevar la identidad digital de la persona. Es un dispositivo similar a un pendrive, que en lugar de memoria contiene un chip de seguridad capaz de llevar a cabo operaciones criptográficas. Típicamente son *driverless* para dotarlos de la máxima facilidad de uso.



Figura 16 Token USB

6.1.4 Hardware Security Module (HSM). Firma en la nube

Un HSM es un dispositivo criptográfico basado en hardware que genera, almacena y protege claves criptográficas y suele aportar aceleración hardware para operaciones criptográficas. Extensivamente usados por las Autoridades de Certificación (CA) y servidores SSL, se plantea su nuevo uso como contenedores de claves privadas de usuarios, a las que éstos acceden para realizar firmas en remoto.

Sus funciones habituales son:

- Almacenamiento seguro de claves anti-tampering.
- Funciones criptográficas simétricas.
- Funciones criptográficas asimétricas.
- Funciones Hash
- Generador de números aleatorios
- Generador de claves asimétricas
- Aceleración SSL

Fabricantes de HSM son mencionables Thales (nCipher), SafeNet (Luna), ARX, o RealSec, que soportan habitualmente las API criptográficas estándar incluyendo PKCS#11, Microsoft CryptoAPI, y Java Cryptographic Engine (JCE). En cuanto a su formato, se distribuyen en *appliances*, tarjeta PCI e incluso portable.

Firma en la nube

El Reglamento (UE) 910/2014 abre la posibilidad de realizar firmas remotas o firmas en la nube, en las que el certificado digital no se encuentra en posesión física del titular, sino alojado en un Hardware Security Module (HSM), así como firma móvil. Si se cumplen ciertos requisitos incluso se podrá considerar este tipo de firmas como firmas avanzadas e incluso cualificadas.

El anexo II del Reglamento eIDAS establece los requisitos aplicables a los dispositivos cualificados de creación de firma y a los dispositivos cualificados de creación de sello (QSCD). La generación o la gestión de los datos de creación de firmas electrónicas en nombre del firmante solo podrán correr a cargo de un prestador cualificado de servicios de confianza.

En cuanto a la firma electrónica cualificada, el estándar CEN EN 419 241-1 y -2, en conjunción con la certificación del HSM (EN 419 221-5, *Protection profiles for TSP Cryptographic modules - Part 5 Cryptographic Module for Trust Services*) permitirá cumplir con los requisitos legales de seguridad.

6.1.5 Carteras de bitcoins

Por su relevancia en los últimos tiempos se realiza a continuación una breve mención al almacenamiento seguro de claves de Bitcoin. Una cartera o monedero Bitcoin es un conjunto de claves privadas, aunque también se refiere al software o hardware que las gestiona y con el que se pueden realizar transacciones.

La pérdida o robo de las claves supone para el titular la imposibilidad de recuperación de la cantidad representada por los Bitcoins, por lo que se recomienda crear “carteras en frío” en particiones cifradas sin conexión a Internet que luego poder utilizar en los momentos en que así se precise trasladándolas a otro ordenador sí conectado.

La farragosidad del proceso para usuarios no expertos ha hecho que hayan surgido iniciativas para guardar y operar con los Bitcoins de forma segura en diferentes entornos:

- Móviles: Electrum, Broadwallet...
- PC: Armory, Bitcoin Knots...
- Web: BitGo, Green Address...
- Carteras físicas Bitcoin: Trezor...



Figura 17 Trezor

6.2 Mecanismos biométricos

La biometría se refiere a las métricas relacionadas con características humanas, que pueden ser utilizadas como medios de identificación y acceso. Incluye aspectos referentes a fisiología (sistemas estáticos) o comportamiento (sistemas dinámicos), que cumplan las siguientes siete condiciones:

- universalidad,
- unicidad,
- permanencia,
- mensurabilidad,
- rendimiento (o exactitud),
- aceptación
- elusión (capacidad de imitación).

En el proceso de autenticación de un individuo, el sistema realiza una comparación de las características biométricas capturadas con un patrón o plantilla almacenado en una base de datos desde el momento del registro inicial. Se define un umbral o sensibilidad aceptable.

Por otro lado, y debido a la natural degradación de las citadas características físicas (iris, huellas...), se suelen utilizar sistemas multimodales (que combinan técnicas estáticas y dinámicas) en los que varios sensores de una misma o varias características captan la información de forma paralela o secuencial y la fusionan, de forma que la decisión final sobre una identificación podría ser tomada incluso por mayoría de apreciaciones.

6.2.1 Rendimiento

En cuanto al rendimiento, se suelen utilizar las siguientes métricas:

- **FMR** (False Match Rate), también conocida como FAR (False Accept Rate). Probabilidad de falsos positivos.
- **FNMR** (False non-match rate), también FRR (False Reject Rate). Probabilidad de falso negativo. Es evidente el FMR y el FNMR dependerán del umbral de discriminación que se defina para la precisión del sistema, de forma que un umbral de sensibilidad bajo aumentará los falsos positivos y disminuirá los falsos negativos.
- Curva ROC (Receiver operating characteristic, Característica Operativa del Receptor). Es una curva que representa la razón entre verdaderos y falsos positivos según varía el umbral de discriminación.
- EER o CER (Equal error rate o crossover error rate, tasa de error de cruce): umbral en el que se cruzan las curvas FMR y FNMR, se obtiene fácilmente a partir de la curva ROC. En general, cuanto menor EER, más preciso será el dispositivo.
- FTE o FER (Failure to enroll rate). Suele estar causada por entradas de baja calidad.
- FTC (Failure to capture rate). Probabilidad de que el sistema no detecte una entrada biométrica.
- Capacidad de patrón. Número máximo de conjuntos en la base de datos.

6.2.2 Estandarización

Había relativamente pocos estándares biométricos antes del cambio de siglo, si bien el estándar ANSI/NBS-ICST 1-1986 se utilizó durante muchos años para el intercambio de datos de huellas dactilares entre fuerzas policiales.

Las organizaciones internacionales más activas en el desarrollo de estándares biométricos son la ISO y la ITU-T. Pero también consorcios industriales desarrollan estándares, así como algunas agencias

especializadas de la ONU, como la International Civil Aviation Organization (ICAO) para la estandarización de los lectores de documentos de viaje como pasaportes.

ISO/IEC

El ISO/IEC Joint Technical Committee 1 (JTC 1) ha publicado gran cantidad de estándares gracias a sus Subcomités 17 (tarjetas e identificación personal), 27 (seguridad) y sobre todo 37 (estándares genéricos), desde 2002. Un resumen sería:

- **ISO/IEC 19794: Biometric data interchange format.**
 - 19794-1 - Framework
 - 19794-2 - Finger minutiae data
 - 19794-3 - Finger pattern spectral data
 - 19794-4 - Finger image data
 - 19794-5 - Face image data
 - 19794-6 - Iris image data
 - 19794-7 - Signature/sign time series data
 - 19794-8 - Finger pattern skeletal data
 - 19794-9 - Vascular image data
 - 19794-10 - Hand geometry silhouette data
 - 19794-11 - Signature/sign processed dynamic data
 - 19794-13 - Voice data
 - 19794-14 - DNA data
 - 19794-15 - Palm crease image data
- ISO/IEC 19784
 - **19784-1 (Biometric application programming interface BioAPI).** Sobre la base de los trabajos previos del Consorcio BioAPI, esta especificación define un interfaz que permite la comunicación con dispositivos biométricos, incluyendo alistamiento, verificación y autenticación, así como un interfaz con la base de datos. Compatible con ISO/IEC 19785 y 19794. Revisiones posteriores incluyeron un BioGUI.
 - 19784-2. BioAPI Part 2: Biometric archive function provider interface
 - 19784-4. BioAPI Part 4: Biometric sensor function provider interface
- ISO/IEC 19785: Common Biometric Exchange Formats Framework
- ISO/IEC 19795: Biometric performance testing and reporting
- ISO/IEC 24709: Conformance testing for the biometric application programming interface (BioAPI). Se trata de evaluar la conformidad de los productos que afirman cumplir la especificación BioAPI (ISO/IEC 19784-1).

ITU-T

Comenzó los trabajos el Study Group 17 en 2001 y ha publicado varias recomendaciones:

- Recomendación ITU-T X.1081: *The telebiometric multimodal model — A framework for the specification of security and safety aspects of biometrics*
- Recomendación ITU-T X.1083 | ISO/IEC 24708: *BioAPI interworking protocol*
- Recomendación ITU-T X.1082 (11/2007) | IEC 80000-14: *Telebiometrics related to human physiology*
- Recomendación ITU-T X.1089: *Telebiometrics authentication infrastructure (TAI)*. Define **certificados biométricos** para la autenticación remota, extendiendo la recomendación sobre certificados electrónicos X.509 e ISO/IEC 24761, mediante la combinación de extensiones X.509 y telecomunicaciones, conocida como “*Telebiometrics authentication infrastructure (TAI)*”.

Tendencias

Se tiende a la inclusión de codificación XML para el uso de biometría en arquitecturas orientadas al servicio. Así, los formatos de ADN y voz se han desarrollado de forma nativa en XML.

Por su parte, OASIS ha desarrollado un estándar llamado Biometric Identity Assurance Services (BIAS), basado en XML y que incluye un perfil SOAP.

6.2.3 Tecnologías biométricas

Fisiológicas

- **Huella dactilar**

Es el sistema que primero se implantó y goza de gran popularidad. Dos tecnologías de búsqueda de coincidencias:

- a) Basadas en minucias o formas fácilmente identificables existentes en la huella.
- b) Basadas en correlación del patrón global.

- **Reconocimiento de palma de la mano**

Tiene una alta FAR por lo que raramente se utiliza en entornos críticos.

- **Reconocimiento de iris**

Se realiza el escaneo del iris con una cámara infrarroja de alta resolución.

- **Reconocimiento de retina**

Se refiere a los vasos circulatorios de la retina.

- **Reconocimiento de voz**

- **Reconocimiento craneal y facial**

Se suelen utilizar dos cámaras, para captar la luz visible e infrarroja, y modelar el cráneo en 3D, mucho más fiable que el mero reconocimiento facial en 2D, que no es fiable al ser fácilmente engañado con fotografías, si bien se aplican técnicas de detección de parpadeo y de movimiento de labios.

- **Reconocimiento vascular**

Se refiere al patrón vascular del dedo, que es único y muy complicado de suplantar.

- **Reconocimiento de DNA**

- **Reconocimiento de olor por composición química**

De comportamiento

Existen características de la persona relacionadas con su comportamiento (*behaviometrics*), incluyendo:

- Patrón de teclado
- Firma manuscrita, incluyendo forma, velocidad, presión y ángulo
- Reconocimiento de forma de andar

6.2.4 Retos

Existen importantes retos en la utilización de tecnologías biométricas, relacionados fundamentalmente con la privacidad, fiabilidad y seguridad.

Una de las principales críticas a estos sistemas reside en la necesidad de garantizar la seguridad de las bases de datos biométricos, ya que su manipulación podría generar denegaciones de servicio, así como su duplicación podría implicar falsos positivos por modelización e imitación⁶. Téngase en cuenta que una contraseña siempre se puede cambiar, pero no una característica física, que es permanente e irrevocable.

⁶<https://www.theguardian.com/technology/2014/dec/30/hacker-fakes-german-ministers-fingerprints-using-photos-of-her-hands>

Asimismo, es complicado probar el repudio de un delito si ha sido cometido por una persona que ha suplantado la identidad física de otra. Debido a este grave problema, se han propuesto algunas alternativas para la cancelación de datos biométricos pero son sólo experimentales.

Es posible, asimismo, que la información obtenida en el registro se utilice para fines distintos de los consentidos por el titular, incluyendo su tratamiento por ejemplo para la identificación de enfermedades, lo que podría vulnerar su intimidad, privacidad y la legislación de datos personales si se transmitiese por ejemplo a las compañías de seguros.

Una última consideración es de tipo ético. Se puede argumentar que la biometría es ampliamente utilizada por regímenes autoritarios para el control de la población, así como que reduce el ser humano a una colección de parámetros.

Como conclusión, y teniendo en cuenta que incluso el iris es falsificable⁷, es recomendable limitar el uso de tecnologías biométricas a aplicaciones donde la seguridad y la privacidad no sean una prioridad, y en caso de serlo, emplearlas únicamente en sistemas de autenticación de doble factor.

6.3 Autenticación multifactor. FIDO.

Una vez vistos los distintos mecanismos de autenticación, a través de dispositivos y de biometría, es oportuno reflexionar sobre cuál será la mejor forma de garantizar la correcta identificación y evitar fraudes. Una posible respuesta, ampliamente desplegada, es la autenticación multifactor.

Estos mecanismos se emplean de manera generalizada hoy en día tanto en la realización de firmas electrónicas como en el acceso a Administraciones públicas o al sector privado. Existen de entrada tres vectores de validación:

- algo que se sabe (conocimiento: una contraseña o PIN)
- algo que se tiene (posesión: un teléfono o un token al que se envía una OTP o *One Time Password*, o un certificado electrónico alojado en tarjeta)
- algo que se es (inherencia: biometría)

A ellos se ha propuesto sumar circunstancias como lugar (geolocalización) como el cuarto factor de autenticación, o incluso el tiempo (no podría logarme en un cajero en Madrid y en quince minutos en Barcelona) como quinto factor.

Centrándonos en la autenticación de doble factor (2FA) en el proceso de autenticación, se trata en general de combinar los tres primeros factores de dos en dos, para cada aplicación. Han de ser factores diferentes, es decir, no computa como 2FA un PIN junto a una contraseña.

En cualquier caso, cuando solo se utiliza un solo factor, “algo que se sabe” es más seguro que “algo que se es”. Asimismo, la biometría ha de ir acompañada de un segundo factor de autenticación, como una contraseña u otro mecanismo como tarjeta de identificación.

Lo anterior no implica que la autenticación multifactor sea la panacea o que evite la suplantación en todos los casos, pero es una protección adicional para los usuarios.

FIDO

FIDO (*Fast ID Online*) es una serie de especificaciones de seguridad, independientes de la tecnología subyacente, para autenticación fuerte. Ha sido desarrollada por la FIDO Alliance, e incluye influyentes miembros de la industria SW, HW y de servicios (Google, Facebook, Intel, Visa, Microsoft, Samsung, RSA, PayPal...).

Soporta autenticación multifactor basada en criptografía de clave pública. La idea es que el usuario no tenga que recordar contraseñas complejas, y en vez de utilizar bases de datos de contraseñas, FIDO almacena la información de identificación personal (como los datos biométricos) localmente en

⁷http://media.blackhat.com/bh-us-12/Briefings/Galbally/BH_US_12_Galbally_Iris_Reconstruction_WP.pdf

el dispositivo de usuario, nunca en servidores en la nube. Se protege así la privacidad del usuario, eliminándose la posibilidad de que diferentes servicios puedan trazar su actividad.

La especificación proporciona APIs para diferentes sistemas operativos y dispositivos ya que ha de ser completamente neutra por diseño. La primera especificación FIDO v1.0 vio la luz en diciembre de 2014. Existen dos protocolos soportados por FIDO:

- **Universal Authentication Framework (UAF):** el dispositivo cliente genera un par de claves en el proceso de identificación, conservando el propio dispositivo la clave privada y el servicio online la pública. Al autenticarse, el cliente debe probar posesión de la clave privada firmando un desafío que involucra una huella dactilar, un PIN, reconocimiento de voz o facial... Se elimina así la necesidad de contraseñas (*passwordless experience*), lo que redundaría en un beneficio para el usuario y también elimina la posibilidad de revelación de millones de contraseñas por ataques a servicios.
- **Universal Second Factor (U2F):** se requiere un segundo factor fuerte en HW, como un dispositivo NFC o un token USB (*second factor experience*), de forma que la contraseña pueda ser fácil (un simple PIN).

La FIDO Alliance tiene un programa de certificación de productos a través de laboratorios acreditados. A fecha de julio de 2017, existen cinco laboratorios, entre ellos APPLUS, y 357 productos.

7. DNI electrónico

7.1 Concepto

El Documento Nacional de Identidad (DNI), emitido por la Dirección General de la Policía (Ministerio del Interior), es el documento que acredita, desde hace más de 50 años, la identidad, los datos personales que en él aparecen y la nacionalidad española de su titular.

A lo largo de su vida, el Documento Nacional de Identidad ha ido evolucionado e incorporando las innovaciones tecnológicas disponibles en cada momento, con el fin de aumentar tanto la seguridad del documento como su ámbito de aplicación.

Con la llegada de la Sociedad de la Información y la generalización del uso de Internet se hace necesario adecuar los mecanismos de acreditación de la personalidad a la nueva realidad y disponer de un instrumento eficaz que traslade al mundo digital las mismas certezas con las que operamos cada día en el mundo físico y que, esencialmente, son:

- Acreditar electrónicamente y de forma indubitada la identidad de la persona.
- Firmar digitalmente documentos electrónicos, otorgándoles una validez jurídica equivalente a la que les proporciona la firma manuscrita.

Para responder a estas nuevas necesidades nació el Documento Nacional de Identidad electrónico (DNIe), similar al tradicional y cuya principal novedad es que incorporó un chip que contiene dos certificados digitales: uno de autenticación y otro de firma electrónica.

La introducción del DNI 3.0 desde principios de 2015, con interfaz dual NFC, ha permitido evolucionar y mejorar sus capacidades de interacción, con el objetivo de expandir sus aplicaciones y uso por parte de la ciudadanía.

Con el mismo objetivo se implantó el sistema de firma en la nube Cl@ve, en el que los certificados están alojados en servidores custodiados por el prestador.

7.2 Marco jurídico

- **Ley 59/2003, de firma electrónica**

El documento nacional de identidad electrónico es el documento nacional de identidad que acredita electrónicamente la identidad personal de su titular y permite la firma electrónica de documentos. Todas las personas físicas o jurídicas, públicas o privadas, reconocerán la eficacia del documento nacional de identidad electrónico para acreditar la identidad y los demás datos personales del titular que consten en el mismo, y para acreditar la identidad del firmante y la integridad de los documentos firmados con los dispositivos de firma electrónica en él incluidos.

Los órganos competentes del Ministerio del Interior para la expedición del documento nacional de identidad electrónico cumplirán las obligaciones que la Ley impone a los prestadores de servicios de certificación que expidan certificados reconocidos con excepción de la relativa a la constitución de la garantía de caución.

- **Real Decreto 1553/2005**, de 23 de diciembre, por el que se regula documento nacional de identidad y sus certificados de firma electrónica
- **Real Decreto 869/2013**, de 8 de noviembre, por el que se modifica el Real Decreto 1553/2005, de 23 de diciembre, por el que se regula la expedición del documento nacional de identidad y sus certificados de firma electrónica.
- **Ley Orgánica 4/2015, de 30 de marzo, de protección de la seguridad ciudadana.**

El Documento Nacional de Identidad permite a los españoles mayores de edad que gocen de plena capacidad de obrar y a los menores emancipados la identificación electrónica de su titular, así como la firma electrónica de documentos, en los términos previstos en la legislación específica.

El prestador de servicios de certificación procederá a revocar el certificado de firma electrónica a instancia del Ministerio del Interior, tras recibir éste la comunicación del Encargado del Registro Civil de la inscripción de la resolución judicial que determine la necesidad del complemento de la capacidad para obligarse o contratar, del fallecimiento o de la declaración de ausencia o fallecimiento de una persona.

- **Real Decreto 414/2015, de 29 de mayo, por el que se modifica el Real Decreto 1553/2005.**

La vigencia de los certificados electrónicos reconocidos incorporados al DNle **no podrá ser superior a cinco años**. Se adapta así el RD regulador del DNle a la modificación de la Ley de firma electrónica que permite un tiempo máximo de vigencia de los certificados cualificados de 5 años.

7.3 Usuarios

Téngase en cuenta que el universo varía, puesto que para los certificados alojados en la tarjeta, el firmante o usuario es cualquier ciudadano español, mayor de edad y con plena capacidad de obrar, y que utiliza los certificados voluntariamente.

A diferencia de lo anterior, en relación con los certificados de firma centralizada (DNI en la nube), se entiende por usuario al ciudadano español y extranjero, mayor de edad y con plena capacidad de obrar, y que utiliza el certificado voluntariamente. Se entiende por extranjero una persona con NIE junto con alguno de los documentos oficiales que lo acredite (bien Certificado de Registro de Ciudadano de la UE o bien Tarjeta de Extranjero).

7.4 DNI en tarjeta

DNI 2.0



Figura 18 DNI 2.0

DNI 3.0



Figura 19 DNI 3.0 (anverso)



Figura 20 DNI 3.0 (reverso)

El propósito de la tarjeta soporte del DNI electrónico es contener los datos de filiación del ciudadano, los datos biométricos (modelo dactilar, foto y firma manuscrita) y los dos pares de claves privadas RSA con sus respectivos certificados (autenticación y firma). Esta tarjeta está compuesta de dos partes, la tarjeta física propiamente dicha y el chip electrónico:

7.4.1 Tarjetas físicas

- De acuerdo con el estándar ISO-7816-1.
- Tarjeta de policarbonato.
- La personalización de la tarjeta se realiza mediante la grabación en el cuerpo de la tarjeta con láser destructivo de los datos de filiación, fotografía y firma manuscrita. Este sistema de personalización garantiza la imposibilidad de manipulación de estos datos.
- Cuenta con las más modernas medidas de seguridad ante la manipulación y falsificación del documento, muchas de ellas fácilmente identificables por cualquier persona sin ningún procedimiento especial. El conjunto de todas las medidas hace del DNI electrónico un documento altamente seguro, tanto desde el punto de vista físico, como electrónico.
- En el **DNI 3.0, se ha añadido una antena NFC (Near Field Communication)**
- En el anverso de la tarjeta se encuentran los siguientes elementos:
 - En el cuerpo central:
 - Primer apellido
 - Segundo apellido
 - Nombre
 - Sexo y nacionalidad
 - Fecha de nacimiento
 - Número de serie del soporte físico de la tarjeta
 - Fecha de validez del documento
 - En la esquina inferior izquierda:
 - Número del Documento Nacional de Identidad del Ciudadano, seguido del carácter de verificación (Número de Identificación Fiscal)
 - En el espacio destinado a la impresión de imagen láser cambiante (CLI):
 - La fecha de expedición en formato DDMMAA
 - DNI 2.0: La primera consonante del primer apellido + primera consonante del segundo apellido + primera consonante del nombre (del primer nombre en caso de ser compuesto)
 - DNI 3.0: Fotografía
 - En la esquina inferior derecha:
 - DNI 3.0: CAN (Card Access Number)
 - En la esquina superior derecha:
 - DNI 3.0: Ventana transparente con grabado láser del número de soporte físico
- El reverso de la tarjeta contiene los siguientes elementos:
 - Parte superior:
 - Lugar de nacimiento

- Provincia-país
- Hijo de
- Domicilio
- Lugar de domicilio
- Provincia-país
- DNI 2.0: equipo
- DNI 3.0 lateral: equipo
- Información impresa OCR-B para lectura mecanizada sobre la identidad del ciudadano según normativa OACI (Organización de Aviación Civil Internacional) para documentos de viaje.

El DNI electrónico no contiene ninguna otra información relativa a los datos personales ni de cualquier otro tipo (sanitarios, fiscales, de tráfico...).

7.4.2 Chips

DNI 2.0

- Modelo del Chip: ST19WL34 y ST19WL34A
- Sistema operativo: DNle v1.13
- Capacidad: 32 KB

Contenido del chip: la información en el chip está distribuida en tres zonas con diferentes niveles y condiciones de acceso:

- **Zona PÚBLICA:** Accesible en lectura sin restricciones, contenido:
 - Certificado CA intermedia emisora.
 - Claves Diffie-Hellman.
 - Certificado x509 de componente.
- **Zona PRIVADA:** Accesible en lectura por el ciudadano, mediante la utilización de la Clave Personal de Acceso o PIN, contenido:
 - Certificado de Firma (No Repudio).
 - Certificado de Autenticación (Digital Signature).
- **Zona DE SEGURIDAD:** Accesible en lectura por el ciudadano, en los Puntos de Actualización del DNle.
 - Datos de filiación del ciudadano (los mismos que están impresos en el soporte físico del DNI), contenidos en el soporte físico del DNI.
 - Imagen de la fotografía.
 - Imagen de la firma manuscrita.

DNI 3.0

- Modelo del Chip: SLE78CLFX408AP de Infineon Technologies
- Sistema operativo: DNle v4.0 (versión comercial DNle 3.0)
- Características:
 - 400 KB Flash
 - 8 KB RAM
 - Dual interface
 - Certificación CC EAL 5+

Contenido del chip: la información en el chip está distribuida en dos zonas con diferentes niveles y condiciones de acceso:

- **Zona PÚBLICA:** Accesible en lectura sin restricciones, contenido:
 - Certificado CA intermedia emisora.
 - Claves Diffie-Hellman.
 - Certificado x509 de componente.

- **Certificado de Firma (No Repudio).**
- **Certificado de Autenticación (Digital Signature).**
- **Zona DE SEGURIDAD:** Accesible en lectura por el ciudadano, en los Puntos de Actualización del DNLe.
 - Datos de filiación del ciudadano (los mismos que están impresos en el soporte físico del DNI), contenidos en el soporte físico del DNI.
 - Imagen de la fotografía.
 - Imagen de la firma manuscrita.

Obsérvese que **los certificados en el DNI 3.0 están situados en la zona pública**, desapareciendo la zona privada que existía en el DNI 2.0.

Para ambos:

- Datos Criptográficos: Claves de ciudadano
 - Clave RSA pública de autenticación (*Digital Signature*).
 - Clave RSA pública de no repudio (*ContentCommitment*).
 - Clave RSA privada de autenticación (*Digital Signature*).
 - Clave RSA privada de firma (*ContentCommitment*).
 - Patrón de impresión dactilar.
 - Clave Pública de root CA para certificados card-verificables.
 - Claves Diffie-Hellman.
- Datos de Gestión:
 - Traza de fabricación.
 - Número de serie del soporte.

El chip de la tarjeta, tanto en 2.0 como en 3.0, almacena los siguientes certificados electrónicos:

1. **Certificado de componente.** Su propósito es la autenticación de la tarjeta del DNI electrónico mediante el protocolo de autenticación mutua definido en CWA 14890. Permite el establecimiento de un canal cifrado y autenticado entre la tarjeta y los drivers. No estará accesible directamente por los interfaces estándar (PKCS11 o CSP). No es para uso directo del ciudadano ni está expedido a su nombre.
2. **Certificado de autenticación.** Tiene como finalidad garantizar electrónicamente la identidad del ciudadano al realizar una transacción telemática. El Certificado de Autenticación (*Digital Signature*) asegura que la comunicación electrónica se realiza con la persona que dice que es. Téngase en cuenta, no obstante, que los certificados de autenticación no se encuentran entre los certificados cualificados regulados por el Reglamento (UE) 910/2014.
3. **Certificado de firma.** Este certificado es el que se utiliza para la firma de documentos garantizando la integridad del documento y el no repudio en origen. Es un certificado X.509v3 estándar, que tiene activo en el Key Usage el bit de *ContentCommitment* (No Repudio) y que está asociado a un par de claves pública y privada, generadas en el interior del chip del DNI, de donde no pueden salir. Este certificado cualificado y alojado en un Dispositivo Cualificado de Creación de Firma convierte la firma electrónica realizada con el DNLe en firma electrónica cualificada, permitiendo su equiparación legal con la firma manuscrita y su reconocimiento transfronterizo en la UE.

7.4.3 Certificación de la tarjeta como dispositivo cualificado de creación de firma

Desde la fecha de aplicación del Reglamento (UE) 910/2014 (1 de julio de 2016) la Comisión Europea publica una lista de certificados seguros y cualificados de creación de firma.

En España, el organismo encargado de la certificación de estos dispositivos es el Centro Criptológico Nacional (CCN) del Centro Nacional de Inteligencia (CNI), que ha certificado al DNLe:

- DNle 2.0 como dispositivo seguro de creación de firma⁸ de acuerdo con la Directiva 1999/93/CE (goza de la consideración de “cualificado” según art. 51 Reglamento (UE) 910/2014).
- DNle 3.0 como dispositivo cualificado de creación de firma⁹ de acuerdo con el Reglamento (UE) 910/2014.

En consecuencia, las firmas realizadas con el DNI 2.0 y 3.0 son consideradas firmas cualificadas, con efectos jurídicos equivalentes a las firmas manuscritas.

7.5 Cl@ve (DNI en la nube)

La Orden PRE/1838/2014, por la que se publica el Acuerdo de Consejo de Ministros por el que se aprueba Cl@ve, la plataforma común del sector público estatal para la identificación, autenticación y firma electrónica mediante el uso de claves concertadas, establece que el sistema Cl@ve permitirá el acceso a servicios de firma en la nube o firma en servidor basada en certificados electrónicos cualificados alojados de forma centralizada (en HSM).

Ya se habló en un apartado anterior de las características que debía poseer un sistema de firma en la nube de acuerdo con el Reglamento (UE) 910/2014 y sus disposiciones de desarrollo.

La implantación de este sistema por parte de la Dirección General de la Policía, junto con la Gerencia de Informática de la Seguridad Social, como prestador de servicios de confianza, en concreto de firma electrónica, culminó en 2016 con la emisión de los primeros certificados centralizados (OID: 2.16.724.1.2.2.2.11).

El prestador garantiza, de acuerdo con la definición de firma avanzada, que las claves permanecen con un alto nivel de confianza bajo el control exclusivo del titular del certificado, quien deberá guardar la diligencia necesaria en la custodia del secreto que permite su acceso.

Para garantizar la unicidad de los nombres de los titulares que figuran en los certificados emitidos por las CA del DNle, aquellos que sean emitidos de forma centralizada incluirán el literal “FIRMA CENTRALIZADA” en el nombre común del certificado.

Los certificados se generarán automáticamente cuando un usuario que se haya registrado en el sistema Cl@ve solicite expresamente su expedición, que se efectuará cuando se vaya a realizar una firma.

Pueden existir duplicaciones de las claves privadas en posesión de la GISS, de acuerdo con el anexo II del Reglamento (UE) 910/2014, con objeto de garantizar la continuidad de los servicios de firma centralizada.

Los HSM que alojan las claves se encuentran certificados según las normas Common Criteria EAL4+ con extensiones ALC_FLR.1 y AVA_VAN.5 así como FIPS 140-2 nivel 3.

Para la activación de la clave privada de firma en la nube, se requiere la introducción de Cl@ve permanente, siendo necesario un código de usuario (NIF/DNI), una contraseña sólo conocida por el ciudadano (no almacenada por el prestador, se comparan hashes), y un segundo factor de autenticación.

7.6 Periodo de validez

Se deben contemplar dos aspectos.

⁸https://oc.ccn.cni.es/index.php?option=com_content&view=article&id=321:2016-03-04-07-58-40&catid=38:relacion-productos-certificados-publico&Itemid=102&lang=es

⁹https://oc.ccn.cni.es/index.php?option=com_content&view=article&id=331%3A2017-02-03-09-42-00&catid=38%3Arelacion-productos-certificados-publico&Itemid=102&lang=es

En primer lugar, la validez de la tarjeta-soporte que, conforme al art. 6 del **RD 1553/2005**, de 23 de diciembre, modificado por el **RD 869/2013**, de 8 de noviembre, tiene los siguientes periodos de validez:

- a) Dos años, cuando el solicitante no haya cumplido los cinco años de edad.
- b) Cinco años, cuando el titular haya cumplido los cinco años de edad y no haya alcanzado los treinta al momento de la expedición o renovación.
- c) Diez años, cuando el titular haya cumplido los treinta y no haya alcanzado los setenta.
- d) Permanente cuando el titular haya cumplido los setenta años.
- e) Excepcionalmente, permanente para mayores de 30 años con gran invalidez, o 1 año en determinadas circunstancias.

En segundo lugar se debe considerar la validez de los certificados contenidos en el chip de la tarjeta del DNI electrónico que tendrán un período de vigencia de **60 meses (5 años)** desde la emisión de los mismos, salvo si la fecha de caducidad del documento es inferior a esos 60 meses, caso en el que se impondrá la limitación a la fecha de caducidad del mismo. En relación con los certificados de firma en servidor, tienen una caducidad máxima de 60 meses a contar desde el día de su expedición a las 24:00 horas.

Debido a que la Ley de firma electrónica ha sido modificada para permitir un periodo máximo de **validez de un certificado cualificado de 5 años**, se ha hecho coincidir la renovación de la tarjeta con la posible renovación de los certificados asociados. Es una mejora de notoria importancia, puesto que la anterior regulación los limitaba a 30 meses y solo se podían renovar una vez caducados o dentro de los 30 días de la fecha de caducidad.

7.7 Particularidades de la PKI del DNle

7.7.1 Arquitectura

De acuerdo con su Declaración de Prácticas de Certificación (DPC), el DNle se expide mediante una PKI de tres niveles, tal y como se explicó en el apartado de este tema dedicado a las arquitecturas de PKI.

De acuerdo con la información publicada en la Lista de Confianza (TSL) a fecha julio de 2017, el prestador “Dirección General de la Policía” tiene publicada la PKI tanto en versión SHA-1 (en extinción) como SHA-256, y existen tres Autoridades de Certificación subordinadas a la raíz y que emiten los certificados finales de ciudadano.

La raíz tiene una longitud de clave de 4096 bits, mientras que tanto las subordinadas (CA) como los certificados finales de usuario tienen una longitud de clave de 2048 bits.

7.7.2 Autoridades de Registro

Como Autoridades de Registro, se utilizan todas las oficinas de expedición del DNI, que garantizan la correcta identificación del ciudadano y la entrega de las claves al solicitante.

A ellas se unen las oficinas de la AEAT y de la Seguridad Social, en relación con el sistema Cl@ve (DNle en la nube en relación con las firmas de documentos).

7.7.3 Autoridades de Validación

En cuanto a la Autoridad de Validación, que tiene como tarea suministrar información sobre la vigencia de los certificados electrónicos que hayan sido expedidos por las Autoridades de Certificación, en la PKI del DNle se ha optado por asignar las funciones de Autoridad de Validación a entidades diferentes de la Autoridad de Certificación, a fin de aislar la comprobación de la vigencia de un certificado electrónico de los datos de identidad de su titular.

Así, la Autoridad de Certificación (Ministerio del Interior – Dirección General de la Policía) no tiene en modo alguno acceso a los datos de las transacciones que se realicen con los certificados que ella emite y las Autoridades de Validación no tiene acceso a la identidad de los titulares de los certificados electrónicos que maneja, reforzando la transparencia del sistema.

Para la validación del DNI electrónico se dispone de dos prestadores de Servicios de Validación:

- **Fábrica Nacional de Moneda y Timbre – Real Casa de la Moneda**, que prestará sus servicios de validación con carácter universal: ciudadanos, empresas y Administraciones Públicas.
- **Ministerio de Hacienda y Administraciones Públicas**, que prestará los servicios de validación al conjunto de las Administraciones Públicas.

Adicionalmente, la entidad pública empresarial Red.es podría completar los servicios de validación en el futuro.

La prestación de estos servicios de validación se realiza con base en Online Certificate Status Protocol (OCSP), lo que, en esencia, supone que un cliente OCSP envía una petición sobre el estado del certificado a la Autoridad de Validación, la cual, tras consultar su base de datos, ofrece vía HTTP una respuesta sobre el estado del certificado. Se destaca que las CRL del DNle no son públicas.

7.8 Requisitos para su uso

Para la utilización del DNI electrónico es necesario contar con determinados elementos hardware y software que permitirán el acceso a los certificados contenidos en el chip. Siendo el DNI 3.0 un dispositivo de interfaz dual, es posible conectarse a la tarjeta de dos formas:

7.8.1 Mediante contactos

a) Elementos hardware

El DNI electrónico requiere el siguiente equipamiento físico:

- Un Ordenador personal (Intel -a partir de Pentium III- o tecnología similar).
- Un lector de tarjetas inteligentes que cumpla el estándar ISO 7816. Existen distintas implementaciones, bien integrados en el teclado, bien externos (conectados vía USB) o bien a través de una interfaz PCMCIA.

Para elegir un lector que sea compatible con el DNI electrónico se ha de verificar que, al menos,

- Cumpla el estándar ISO 7816 (1, 2 y 3)
- Soporta tarjetas asíncronas basadas en protocolos T=0 (y T=1)
- Soporta velocidades de comunicación mínimas de 9.600 bps.
- Soporta los estándares:
 - API PC/SC (Personal Computer/Smart Card)
 - CSP (Cryptographic Service Provider, Microsoft)
 - API PKCS#11

b) Elementos software para PC

1.- Sistemas operativos

El DNI electrónico puede operar en diversos entornos:

- Microsoft Windows 7 y superiores
- Linux
- Unix
- Mac

2.- Navegadores

- Microsoft Internet Explorer
- Mozilla Firefox
- Chrome

3.- Controlador del lector

4.- Controladores / Módulos criptográficos

- Entorno Microsoft Windows: Minidriver o CardModule (instalación manual o automática) y PKCS#11.
- En los entornos UNIX / Linux o MAC: PKCS#11

7.8.2 Mediante NFC (sin contactos)

a) Elementos hardware

Un dispositivo que cumpla el estándar ISO 14443, tipo A o B (el DNI 3.0 es compatible con ambas), partes 1/2/3/4, protocolo de transmisión T-CL. Podrá ser un Smartphone, Tablet o lector NFC.

b) Elementos software

App que use el DNle para identificarse y acceder a un servicio o realizar firma de documentos, y se descargue vía repositorio de apps o de la página web de la entidad u organismo.

7.9 Aplicaciones

Hasta la creación del DNI 3.0, para la utilización de los servicios de la Administración electrónica o la realización de cualquier otro trámite relativo a la identidad electrónica, era necesario un lector externo que conectara el DNI con el dispositivo en cuestión.

Sin embargo, con la implantación del DNI 3.0 y con la nueva tecnología NFC, únicamente será necesario aproximar el DNI al dispositivo para realizar la conexión y sacar máximo rendimiento de las utilidades de la identidad electrónica.

Hasta el momento, la Fábrica Nacional de Moneda y Timbre, conjuntamente con la Policía Nacional, ha desarrollado diversas aplicaciones (Apps) con la finalidad de promocionar y publicitar la utilización de la identidad electrónica del DNI, comprobar sus posibilidades, y que diversos entes desarrolladores de aplicaciones utilicen el código fuente del funcionamiento del DNI para diseñar sus propias aplicaciones.

Las apps creadas están disponibles en el repositorio oficial de Google Play buscando por el desarrollador “CNP-FNMT” para dispositivos móviles con sistema operativo Android 4.2 o superior. Se ofrece un “panel de control” completo para gestionar versiones, instrucciones de uso, generar estadísticas de uso, etc:

- DGT¹⁰ (puntos, multas...)
- Seguridad Social (vida laboral...)
- AEAT (renta, datos fiscales...)
- Catastro

Al respecto, se ha publicado una guía de descripción técnica de aplicaciones Android sobre DNI 3.0¹¹.

7.10 Seguridad

Para hacer uso del DNI electrónico en los términos expuestos anteriormente, éste provee las siguientes funciones de seguridad:

7.10.1 Autenticación

La tarjeta DNle dispone de distintos métodos de autenticación, mediante los que una entidad externa demuestra su identidad, o el conocimiento de algún dato secreto almacenado en la tarjeta. La correcta realización de cada uno de estos métodos, permite obtener unas condiciones de seguridad, que podrán ser requeridas para el acceso a los distintos recursos de la tarjeta.

- Autenticación de usuario (PIN)

¹⁰ <https://play.google.com/store/apps/details?id=com.dniedgt>

¹¹ https://www.dnielectronico.es/PDFs/Implementacion_NFC_FNMT.pdf

La tarjeta DNle soporta verificación de usuario (CHV- Card Holder Verification). Esta operación es realizada comprobando el código facilitado por la entidad externa a través del correspondiente comando.

En el momento de realizar la verificación de código PIN se establece un canal seguro entre el terminal y la tarjeta con objeto de que el código PIN que se transmite quede securizado.

Cada código CHV tiene su propio contador de intentos. Tras una presentación válida de PIN, el contador de reintentos correspondiente es automáticamente puesto a su valor inicial (típicamente = 3). El contador de intentos es decrementado cada vez que se realiza una presentación errónea, pudiendo llegar a bloquearlo si el contador llega a cero. Es posible desbloquear un código tras una correcta presentación de la huella dactilar del usuario, que en este caso actúa de código de desbloqueo. A su vez estas presentaciones de huellas tienen su propio contador de intentos. Si el número de intentos de presentación de huella dactilar se agota, no será posible realizar la operación de desbloqueo. Es posible cambiar el código de CHV a un nuevo valor presentando el valor actual o presentando la huella dactilar.

El código PIN es personal e intransferible, por tanto, únicamente debe ser conocido por el titular de la tarjeta en cuestión.

- Autenticación de usuarios mediante datos biométricos

La tarjeta DNle permite realizar una identificación biométrica del titular de ésta, si bien esta función sólo estará disponible en puntos de acceso controlados.

La aplicación que accede al DNle, una vez conocida la información sobre las huellas contenidas en la tarjeta, decide sobre qué huella va a proceder a verificar, solicitando al portador que coloque el dedo adecuado. Tras obtener los datos biométricos desde el dispositivo lector de huellas, presenta la información biométrica a la tarjeta a través del correspondiente comando. Tras las comprobaciones iniciales de condiciones de uso y seguridad, la tarjeta procede, mediante su algoritmo Match on Card, a evaluar la correspondencia entre la huella presentada y la referencia.

Si la evaluación supera el umbral, la verificación es correcta. En caso contrario, la tarjeta anota una presentación errónea sobre esa huella devolviendo el número de intentos restantes.

- Autenticación de aplicación

El propósito de este método de autenticación es que la entidad externa demuestre tener conocimiento del nombre y valor de un código secreto. Para realizar esta autenticación de aplicación, se utiliza un protocolo de desafío-respuesta, con los siguientes pasos:

- La aplicación pide un desafío a la tarjeta
- La aplicación debe aplicar un algoritmo a este desafío junto con el correspondiente código secreto y nombre de la clave
- La tarjeta realiza la misma operación y compara el resultado con los datos transmitidos por la aplicación. En caso de coincidir, considera correcta la presentación para posteriores operaciones

- Autenticación mutua

Este procedimiento permite que cada una de las partes (tarjeta y aplicación externa) confíe en la otra, mediante la presentación mutua de certificados, y su verificación.

En el proceso, también se incluye el intercambio seguro de unas claves de sesión, que deberán ser utilizadas para securizar (cifrar) todos los mensajes intercambiados posteriormente. Este servicio permite el uso de diferentes alternativas, que podrán seleccionarse implícitamente en función de la secuencia de comandos, o explícitamente,

indicando su identificador de algoritmo en un comando de gestión de entorno de seguridad anterior (MSE).

Las dos opciones disponibles están basadas en la especificación “CWA 14890-1 Application Interface for smart cards used as Secured Signature Creation Devices – Part 1”, y son las siguientes:

- Autenticación con intercambio de claves.
- Autenticación de dispositivos con protección de la privacidad.

7.10.2 Securización de mensajes

La tarjeta DNle permite la posibilidad de establecer un canal seguro entre el terminal y la tarjeta que securice los mensajes transmitidos. Para el establecimiento es necesaria la autenticación previa del terminal y la tarjeta, mediante el uso de certificados. Durante la presencia del canal seguro los mensajes se cifran y autentican, de tal forma que se asegura una comunicación “uno a uno” entre los dos puntos originarios del canal.

El canal seguro puede ser requerido por la aplicación o puede ser una restricción de acceso impuesta a algún recurso de la tarjeta.

Para el establecimiento del canal seguro, en primer lugar, se realiza un intercambio de las claves públicas de la tarjeta y el terminal mediante certificados que serán verificados por ambas partes. A continuación se realiza un protocolo de autenticación mutua, con intercambio de semillas para la derivación de una semilla común que dé lugar a las claves de sesión de cifrado y autenticado.

Una vez concluido el protocolo para el establecimiento de la semilla común todos los mensajes deben transmitirse securizados.

7.10.3 Desbloqueo y cambio de PIN

Se permite el cambio de PIN, mediante la presentación del valor antiguo. Es posible también el cambio de PIN bajo determinadas condiciones tras la realización de una verificación biométrica.

Debido a la criticidad de esta operación, el cambio de PIN se ha de realizar siempre en condiciones de máxima confidencialidad y en terminales específicamente habilitados a tal efecto o con las debidas condiciones de seguridad, exigiéndose por tanto, el establecimiento de un canal seguro.

El cambio de PIN, haciendo uso de la huella dactilar (desbloqueo), únicamente está permitido en dispositivos autorizados por la Dirección General de la Policía (DGP) y no se puede realizar, bajo ningún concepto, en otros terminales.

7.10.4 Funcionalidad criptográfica

• Claves RSA

La tarjeta DNle es capaz de generar y gestionar claves RSA. La generación de la pareja de claves RSA sigue el estándar PKCS#1 v1.5. Se usa el algoritmo Miller-Rabin como test de primalidad.

• Hash

La tarjeta DNle es capaz de realizar hash de datos con el algoritmo SHA-256. Es posible realizar todo el proceso en la tarjeta o finalizar un hash calculado externamente. Después de finalizar cualquier operación de hash, el código resultante es almacenado en la memoria de la tarjeta para ser usado posteriormente por un comando. El hash sólo permanece en memoria hasta la siguiente operación.

• Firmas electrónicas

La tarjeta DNle tiene capacidad para la realización de firmas electrónicas de dos modos diferentes:

- Modo raw
- Modo relleno PKCS#1

7.10.5 Intercambio de claves

La operación de intercambio de claves es usada para compartir claves simétricas o de sesión entre dos entidades. Es posible cifrar una clave K_s con la clave pública de un destinatario, la cual puede ser cargada en la memoria de la tarjeta protegida mediante una clave RSA. El destinatario puede descifrar la clave K_s usando la clave privada RSA correspondiente.

7.10.6 Cifrado

La tarjeta puede realizar operaciones 3DES CBC con claves de 24 bytes (k_1, k_2, k_1), para lo que la clave ha de ser previamente cargada en memoria en un proceso protegido por RSA. La clave permanece en memoria hasta que se finaliza la sesión con la tarjeta o se carga una nueva.

También puede realizar operaciones AES con claves de 16 bytes.

7.10.7 Aplicaciones de firma

Uno de los principales usos del DNI electrónico es la realización de firma electrónica. Para utilizar esta funcionalidad de firma, numerosas aplicaciones pueden ser empleadas, ya que éstas acceden a las capas o módulos intermedios de CardModule y PKCS#11, que proporcionan un interfaz estándar de acceso a la tarjeta. Para acceder a la tarjeta mediante el interfaz sin contactos deberá tener instalada una app específica.

7.10.8 Requisitos de seguridad del entorno

Para el correcto y seguro funcionamiento de la tarjeta DNle se han de utilizar los módulos criptográficos CardModule y PKCS#11 que se encuentran en la dirección www.dnielectronico.es/descargas/.

Para entornos sin contacto deberá instalarse una app específica que ofrezca un nivel suficiente de confianza.

Estos módulos y las app contienen lo necesario para establecer un entorno seguro en la operación con el DNI electrónico y satisfacer los requisitos de seguridad aplicables al entorno de las tecnologías de la información descritos en el perfil de protección Protection Profiles for Secure Signature Creation Device – part 2: Device with Key Generation.

GLOSARIO

AES	Advanced Encryption Standard
BGP	Border Gateway Protocol
CA	Certification Authority
CAB	Conformity Assessment Body
CAR	Conformity Assessment Report
CEN	Comité Européen de Normalisation
CHV	Card Holder Verification
CRL	Certificate Revocation List
CSP	Cryptographic Service Provider
CWA	CEN Workshop Agreement
DNI	Documento Nacional de Identidad
DNS	Domain Name System
DNSSEC	DNS Security
DSA	Digital Signature Algorithm
EEPROM	Electrically Erasable Programmable Read-Only Memory
eIDAS	electronic IDentification, Authentication and Signatures
ENAC	Entidad Nacional de Acreditación
ENISA	European Union Agency for Network and Information Security
EPROM	Erasable Programmable Read-Only Memory
FIDO	Fast ID Online
GNU	GNU's Not Unix
GnuPG	GNU Privacy Guard
GSM	Group Special Mobile
HSM	Hardware Security Module
HTTPS	Hypertext Transfer Protocol Secure (o sobre SSL/TLS)
IANA	Internet Assigned Numbers Authority
ICANN	Internet Corporation for Assigned Names and Numbers
IEC	International Electrotechnical Commission
IP	Internet Protocol
ISO	International Organization for Standardization
ITU-T	International Telecommunication Union-Telecommunication
LoTL	List of Trusted Lists
NAB	National Accreditation Body
NFC	Near Field Communications
OASIS	Organization for the Advancement of Structured Information Standards
OCF	OpenCard Framework
OCSP	Online Certificate Status Protocol

OTP	One Time Password
PC/SC	Personal Computer/Smart Card
PGP	Pretty Good Privacy
PIN	Personal Identification Number
PKG	Private Key Generator
PKI	Public Key Infrastructure
QSC	Quantum-safe cryptography
QSCD	Qualified Signature Creation Device
QTSP	Qualified Trust Service Provider
RIR	Regional Internet Registry
ROA	Route Origination Authorization
RPKI	Resource Public Key Infrastructure
RSA	Rivest Shamir Adleman
S/MIME	Secure / Multipurpose Internet Mail Extensions
SHA	Secure Hash Algorithm
SSCD	Secure Signature Creation Device
SSL	Secure Socket Layer
STORK	Secure idenTity acrOss boRders linKed
TSL	Trusted Services List
TSP	Trust Service Provider
U2F	Universal Second Factor
UAF	Universal Authentication Framework
USB	Universal Serial Bus

PREGUNTAS DE TEST

- 1) El Reglamento (UE) 910/2014, de 23 de julio de 2014, relativo a la identificación electrónica y los servicios de confianza impuso a los prestadores de servicios de certificación reconocidos conforme a la Directiva 1999/93/CE la obligación de enviar un informe de evaluación de la conformidad:
 - a) El 2 de julio de 2017
 - b) Lo antes posible pero no más tarde del 1 de julio de 2017
 - c) El 1 de julio de 2016
 - d) No existe tal obligación.

- 2) El Reglamento (UE) 910/2014, de 23 de julio de 2014, relativo a la identificación electrónica y los servicios de confianza será aplicable, salvo excepciones:
 - a) A partir del 1 de julio de 2017
 - b) A partir del 1 de julio de 2016
 - c) A los 20 días de su publicación en el Diario Oficial de la UE
 - d) El 29 de septiembre de 2018

- 3) El Reglamento (UE) 910/2014, de 23 de julio de 2014, relativo a la identificación electrónica y los servicios de confianza deroga la Directiva 1999/93/CE. Ello implica que la Ley 59/2003 de firma electrónica:
 - a) También se ve derogada, al ser la transposición de la Directiva.
 - b) Queda jurídicamente desplazada por el Reglamento
 - c) No se ve afectada
 - d) Ninguna de las anteriores

- 4) El Reglamento (UE) 910/2014, de 23 de julio de 2014, relativo a la identificación electrónica y los servicios de confianza prevé el reconocimiento transfronterizo obligatorio de los esquemas de identidad electrónica comunicados a la Comisión, en fecha:
 - a) 1 de julio de 2016
 - b) 29 de septiembre de 2018 en los servicios públicos
 - c) Cuando se desarrollen los Actos de Ejecución previstos y se acuerde la fecha
 - d) 29 de septiembre de 2018 en los servicios públicos y privados

SOLUCIONES A LAS PREGUNTAS DE TEST

PREGUNTA	SOLUCIÓN
1	b
2	b
3	b
4	b

BIBLIOGRAFÍA BÁSICA

- Ministerio de Energía, Turismo y Agenda Digital
<http://www.minetad.gob.es/telecomunicaciones/es-ES/Servicios/FirmaElectronica/Paginas/FirmaElectronica.aspx>
- INCIBE <https://www.incibe.es> ; <https://www.certs.es/>
- Ministerio de Hacienda y Función Pública
<https://administracionelectronica.gob.es/ctt/>
- Ministerio del Interior
www.dnielectronico.es
- Comisión Europea
<https://ec.europa.eu/digital-single-market/en/trust-services-and-eid>
- ETSI www.etsi.org
- ITU www.itu.int
- ISO www.iso.org
- ALAMILLO DOMINGO, José Ignacio
“El nuevo Reglamento europeo de servicios de confianza digital”,
Revista SIC: ciberseguridad, seguridad de la información y privacidad, ISSN 1136-0623, Nº. 110, 2014, págs. 68-69.
- <https://wiki.emercoin.com/en/EMCSSL>
- <https://www.safelayer.com/>
- <https://www.entrust.com/>
- <https://technet.microsoft.com/>
- <http://www.root-dnssec.org/>
- <https://www.iana.org/>
- <https://bitcoin.org/>
- www.planetbiometrics.com
- www.wikipedia.org
- <https://fidoalliance.org>

BIBLIOGRAFÍA PARA AMPLIAR EL TEMA

1. ETSI Quantum Computing Impact on security of ICT SystemsK; Recommendations on Business Continuity and Algorithm Selection (<http://www.etsi.org/technologies-clusters/technologies/quantum-safe-cryptography>)
2. Securing Public Key Infrastructure (PKI) Microsoft IT Information Security and Risk Management (<http://aka.ms/securingpki>)
3. Strickling, Lawrence. "Reviewing the IANA Transition Proposal". National Telecommunications and Information Administration. United States Department of Commerce. (<https://www.ntia.doc.gov/blog/2016/reviewing-iana-transition-proposal>)